

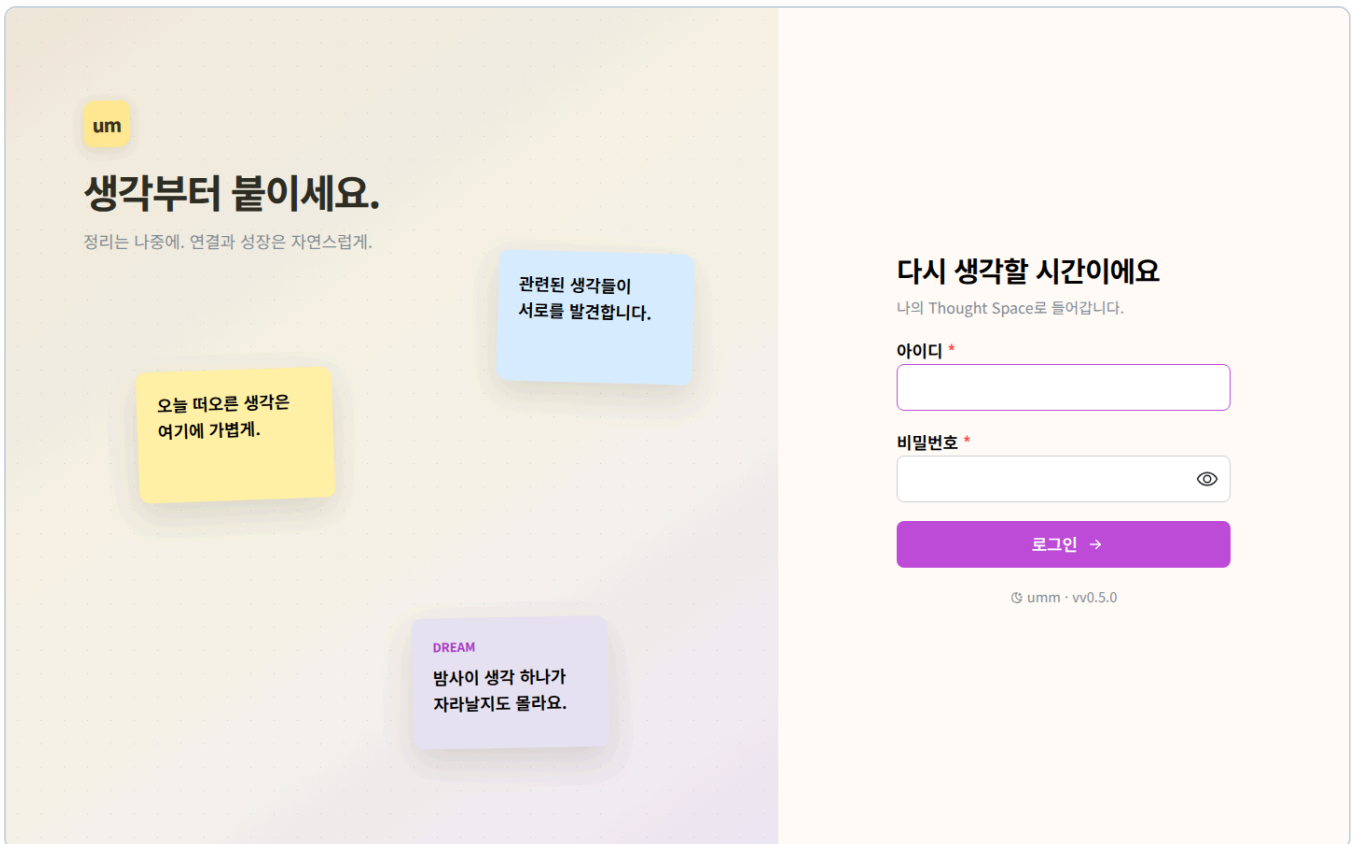


# umm 기능 및 화면 가이드 (Features & UI Guide)

umm 은 생각을 문서나 폴더로 정리하기 전에 공간에 먼저 붙이고, 연결하고, 밤사이 **Dream**으로 다시 발견하는 **Spatial Thought Memory** 플랫폼입니다.

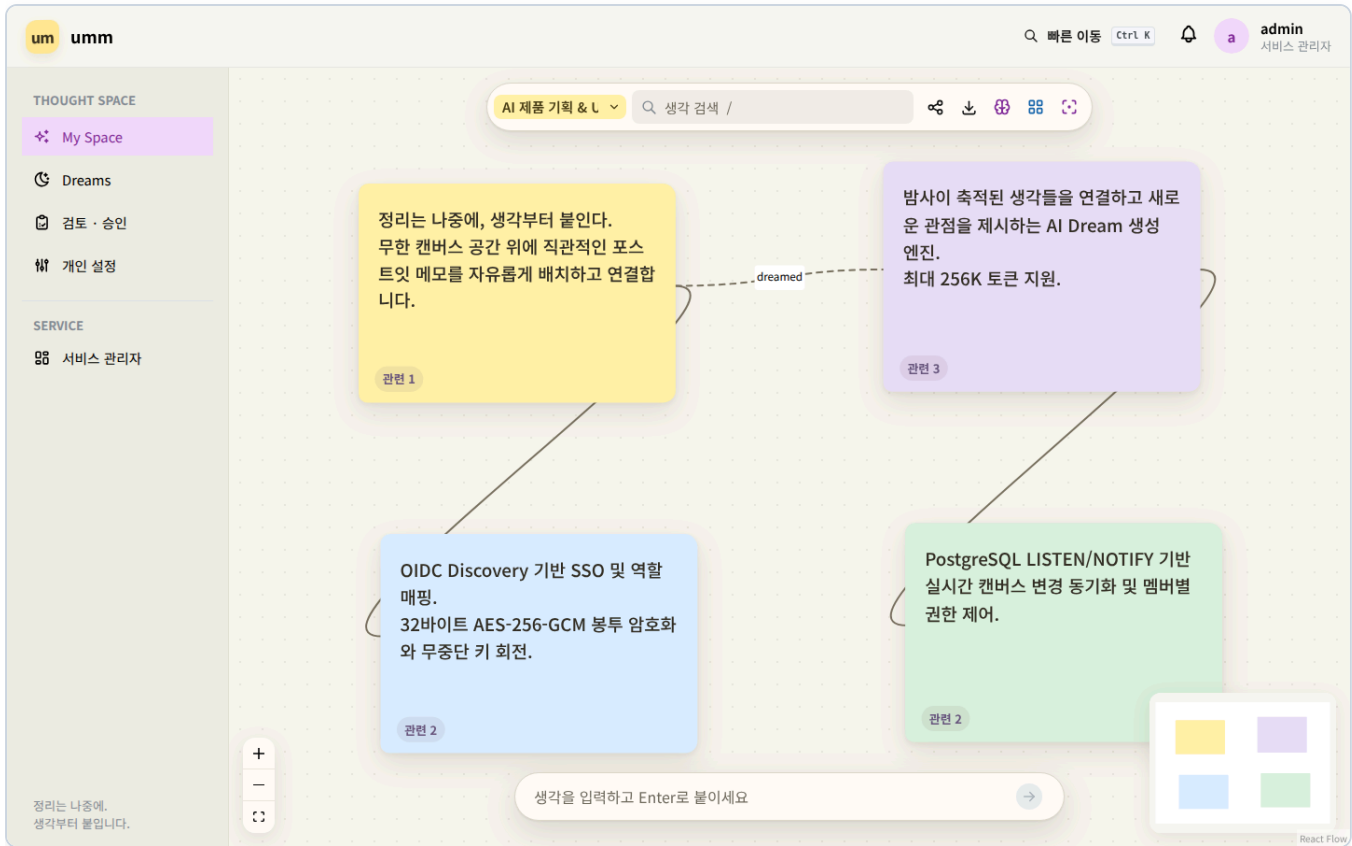
## 📷 전체 메뉴별 주요 화면 및 기능 명세

### 1. 인증 및 로그인 ( /login )



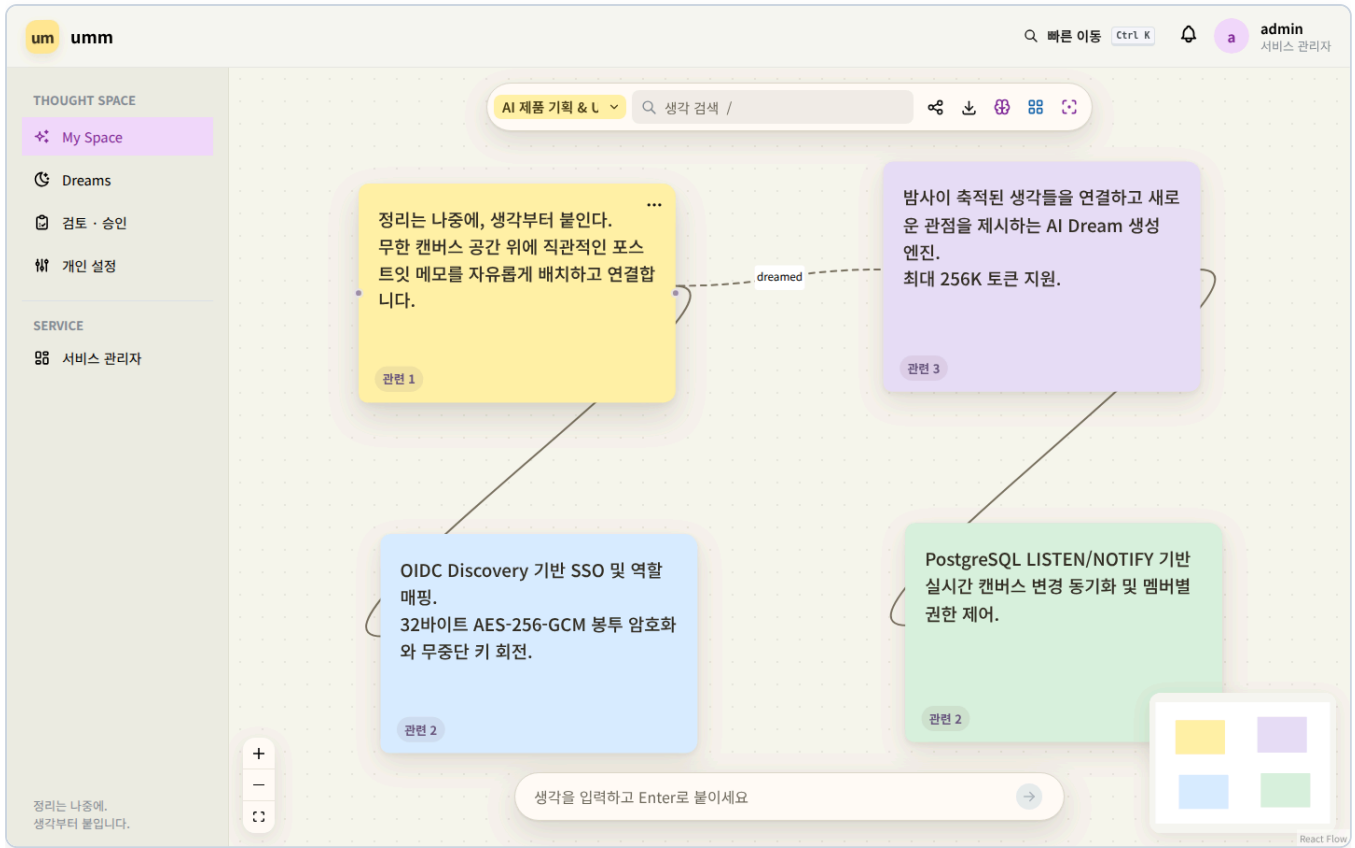
- 로컬 부트스트랩 관리자: 초기 환경변수( `BOOTSTRAP_ADMIN` , `BOOTSTRAP_ADMIN_PASSWORD` ) 기반 보안 로그인
- Keycloak OIDC SSO: 설정 시 `Keycloak SSO로 계속` 버튼을 통한 엔터프라이즈 통합 로그인 지원
- 버전 및 서비스명: 하단에 현재 릴리스 버전( `v0.8.1` )과 서비스명 실시간 표시

## 2. 무한 생각 캔버스 ( /space/:spaceId )



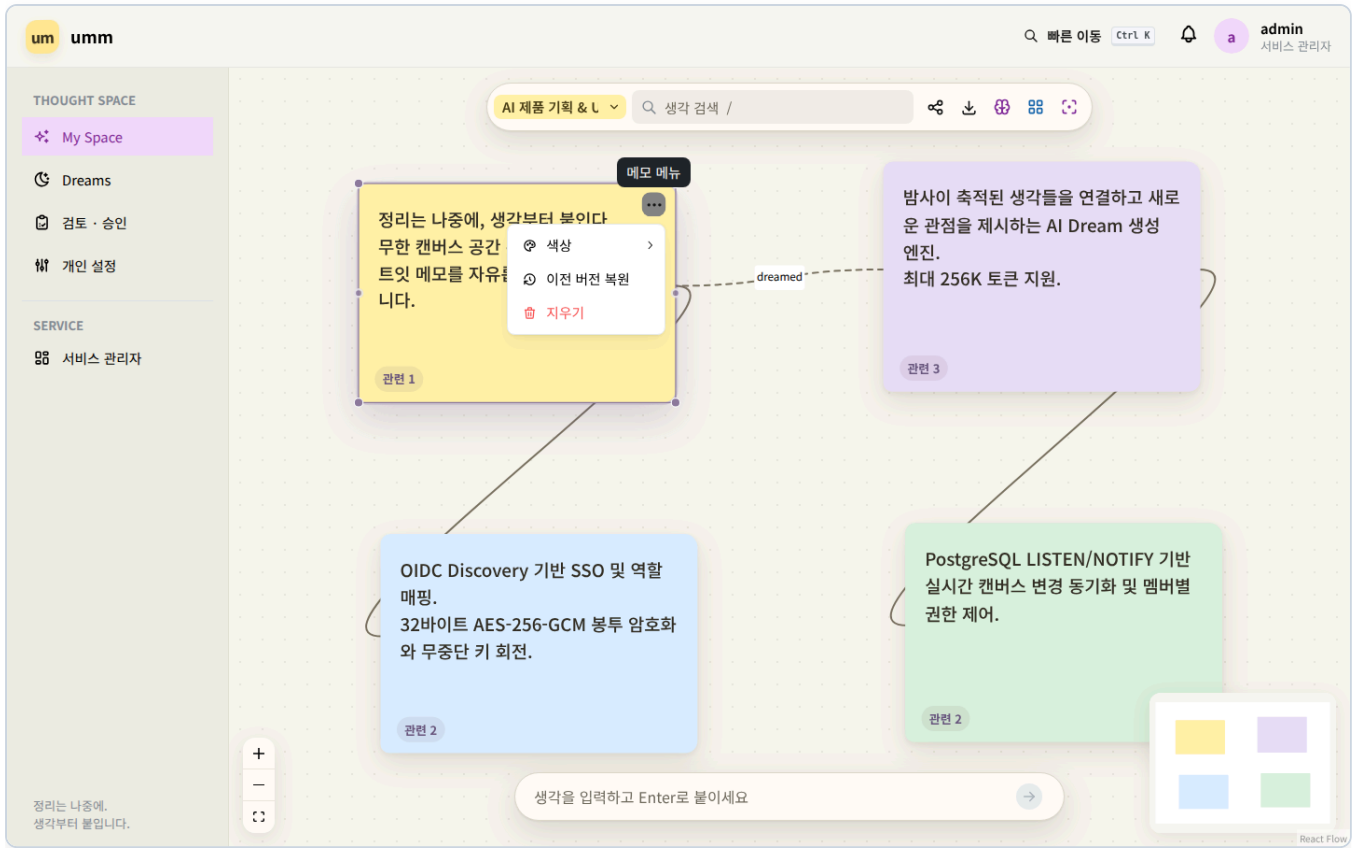
- **Spatial Infinite Canvas**: React Flow 기반의 자유로운 줌(Zoom), 팬(Pan), 미니맵 및 도트 그리드 배경
- **포스트잇 노트 배치**: 더블클릭, **N**, **/** 또는 하단 Quick Capture 바를 통해 공간 어디든 즉시 메모 생성
- **생각 연결선 (Edges)**: 노트 핸들을 드래그하여 생각 간의 관계(관련, Dreamed 등)를 직관적으로 연결
- **실시간 자동 저장**: 저장 버튼 없이 모든 입력, 위치 이동, 크기 변경이 PostgreSQL에 실시간 커밋
- **메모별 AI 제외**: 메모 메뉴에서 민감한 생각을 AI Assist와 Dream 분석 대상에서 제외하고, 외부 호출 직전의 source lease에서도 다시 확인. 외부 임베딩 Gateway에도 본문을 보내지 않고 로컬 vector만 사용

### 3. 포스트잇 상세 편집 및 컬러 테마



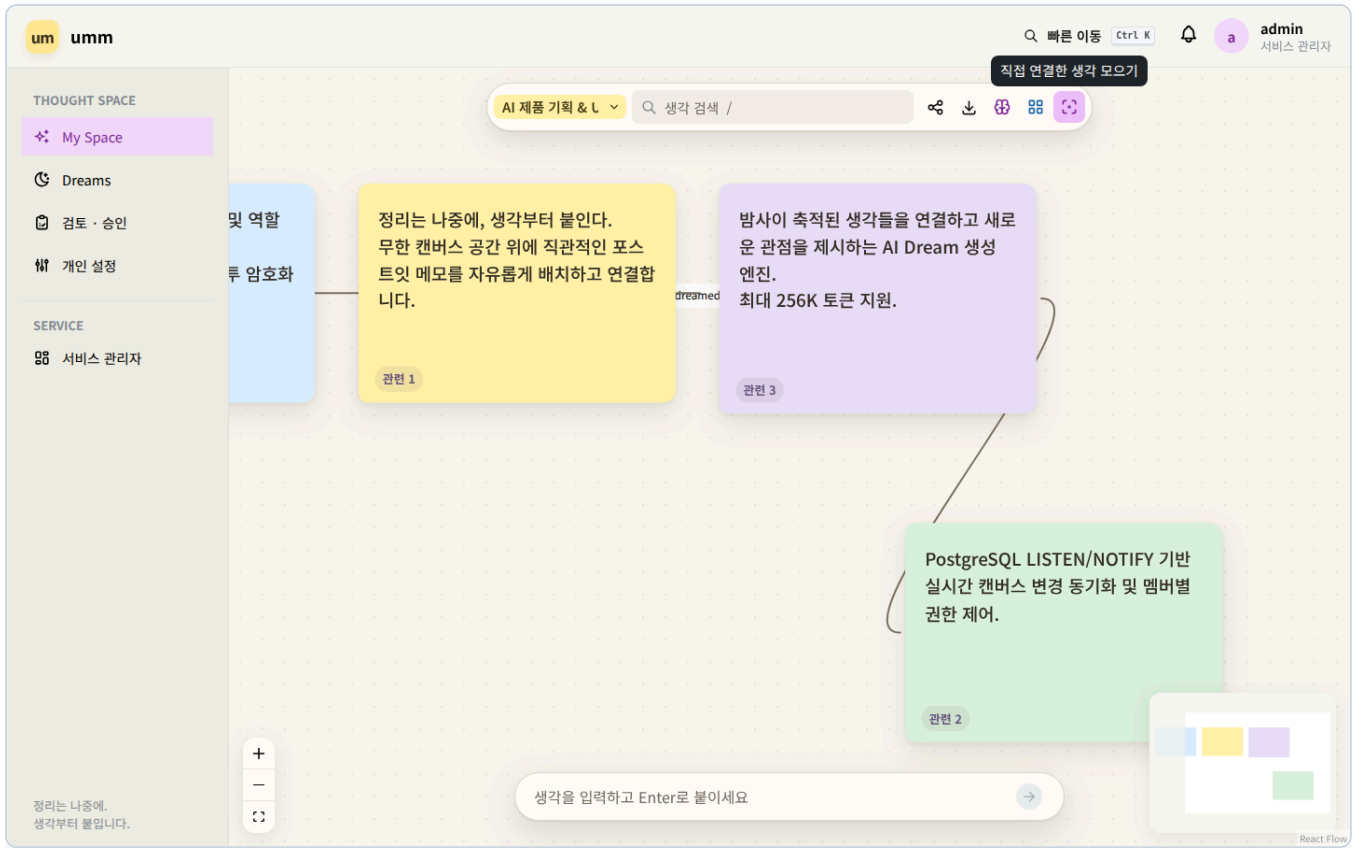
- **7종 Semantic Pastel Palette:** 노랑(Yellow), 파랑(Blue), 보라(Purple), 라벤더(Lavender), 초록(Green), 빨강(Red), 회색(Gray)
- **리사이즈 & 드래그:** 노드 경계면 리사이저로 크기를 자유롭게 조정하고 드래그하여 배치
- **위치 Undo / Redo:** **Cmd+Z** / **Shift+Cmd+Z** 단축키로 이전 위치 및 이동 이력 복원

#### 4. 포스트잇 버전 이력 및 복원 (Revisions & Restore)



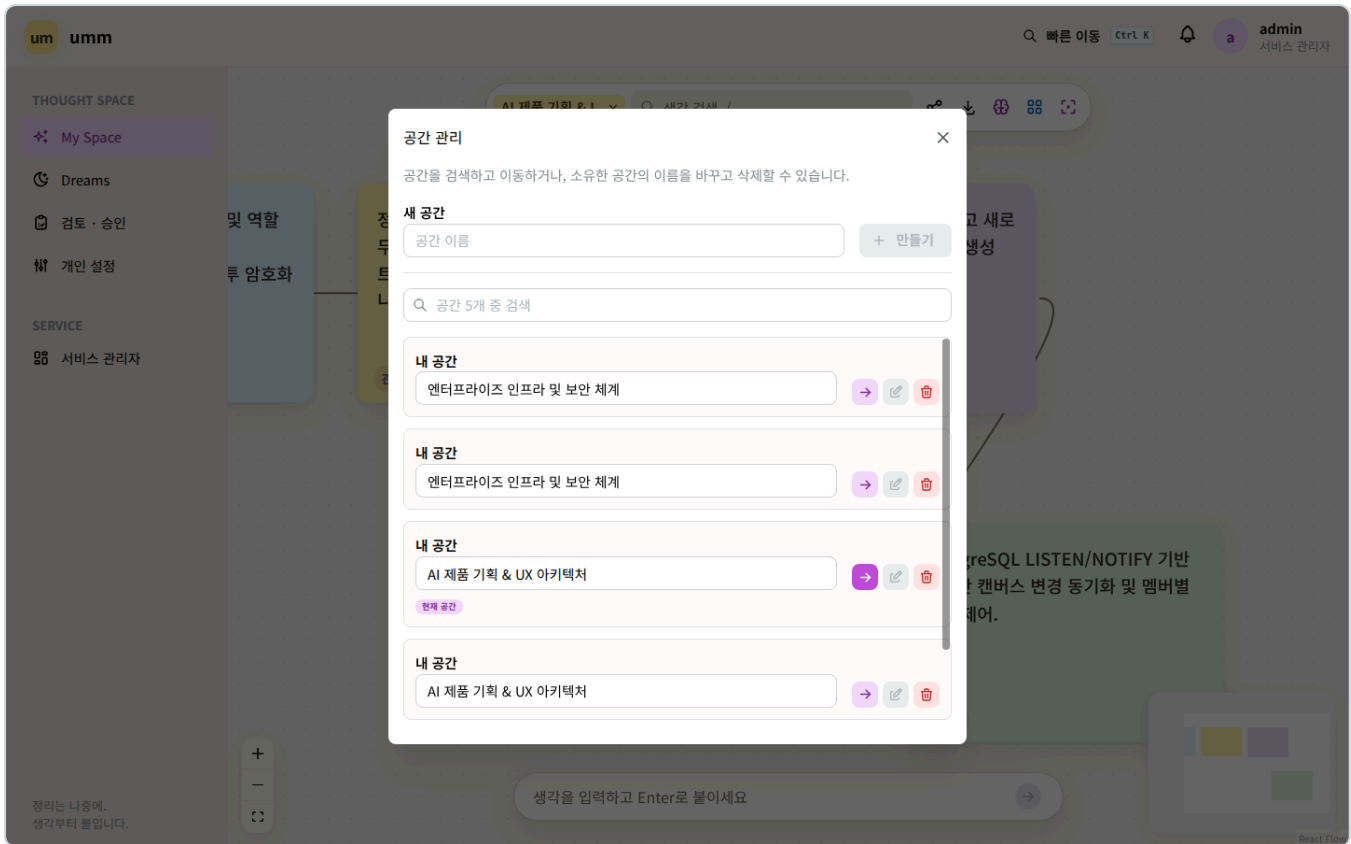
- 버전 스냅샷 자동 생성: 메모 내용 변경 시마다 백그라운드에서 버전 스냅샷 기록
- 이전 버전 롤백: 실수로 변경하거나 삭제된 내용을 특정 시점의 버전으로 안전하게 복원

## 5. Thought Gravity (생각 인력)



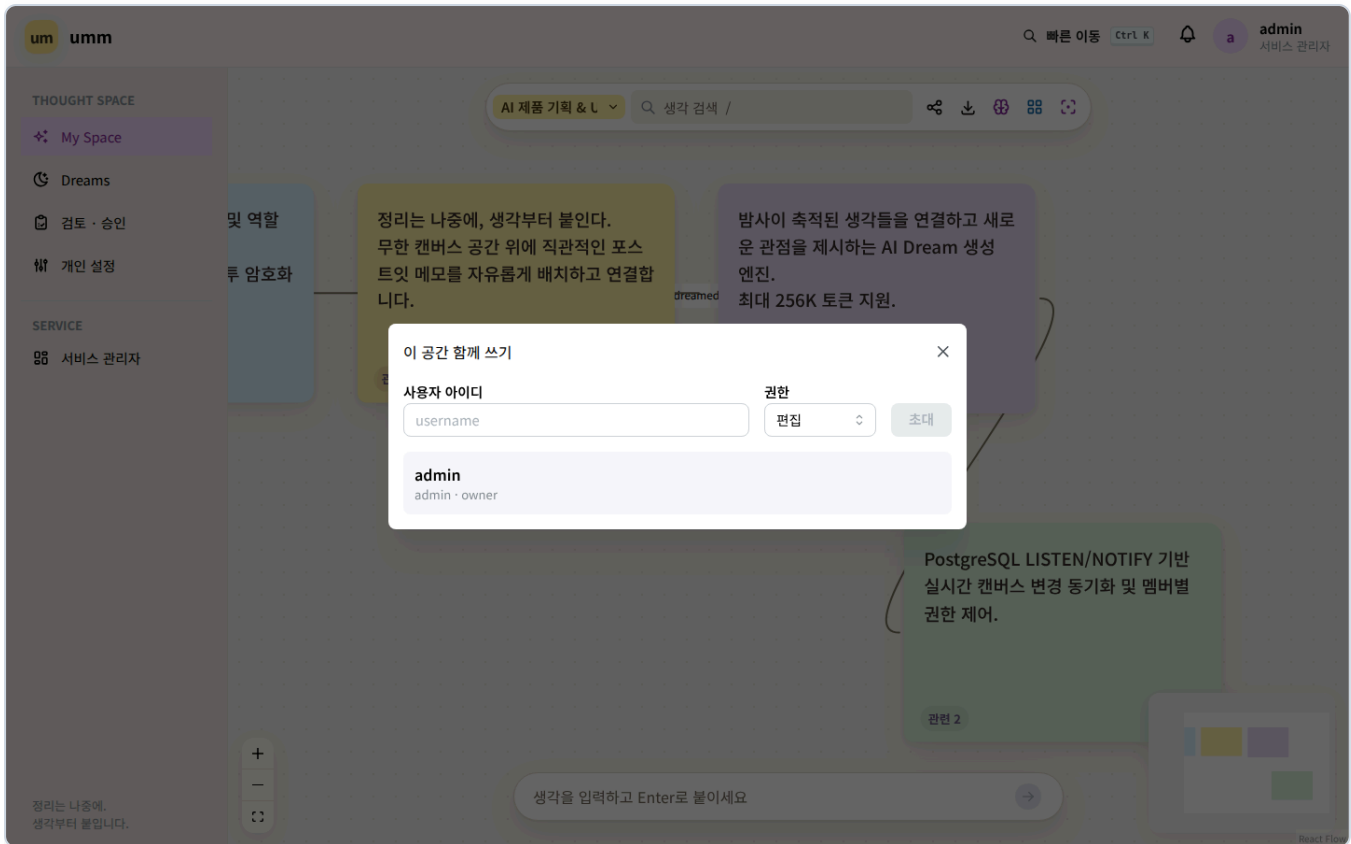
- 원형 궤도 자동 정렬: 중심 생각을 선택하고 **Thought Gravity** 버튼을 누르면 연결된 모든 관련 생각들이 중심 노드 주위 궤도로 자연스럽게 모임
- 복잡한 캔버스 정리: 흩어진 아이디어들을 한 번의 클릭으로 주제별로 집결

## 6. 공간 관리자 (Space Manager)



- **공간 생성 (Create Space):** 새로운 프로젝트 및 생각 주제별 독립 캔버스 생성
- **공간 검색 및 전환:** 등록된 모든 공간을 실시간 검색하고 빠르게 이동
- **공간 이름 변경 및 삭제:** 소유한 공간의 이름을 인라인으로 변경하거나 안전 확인 후 영구 삭제
- **공간별 AI 제외:** 공간 관리에서 전체 공간의 AI Dream 분석을 즉시 켜거나 끄며, 제외 공간의 본문과 해당 공간으로 범위를 제한한 검색어는 외부 임베딩 Gateway에도 전송하지 않음

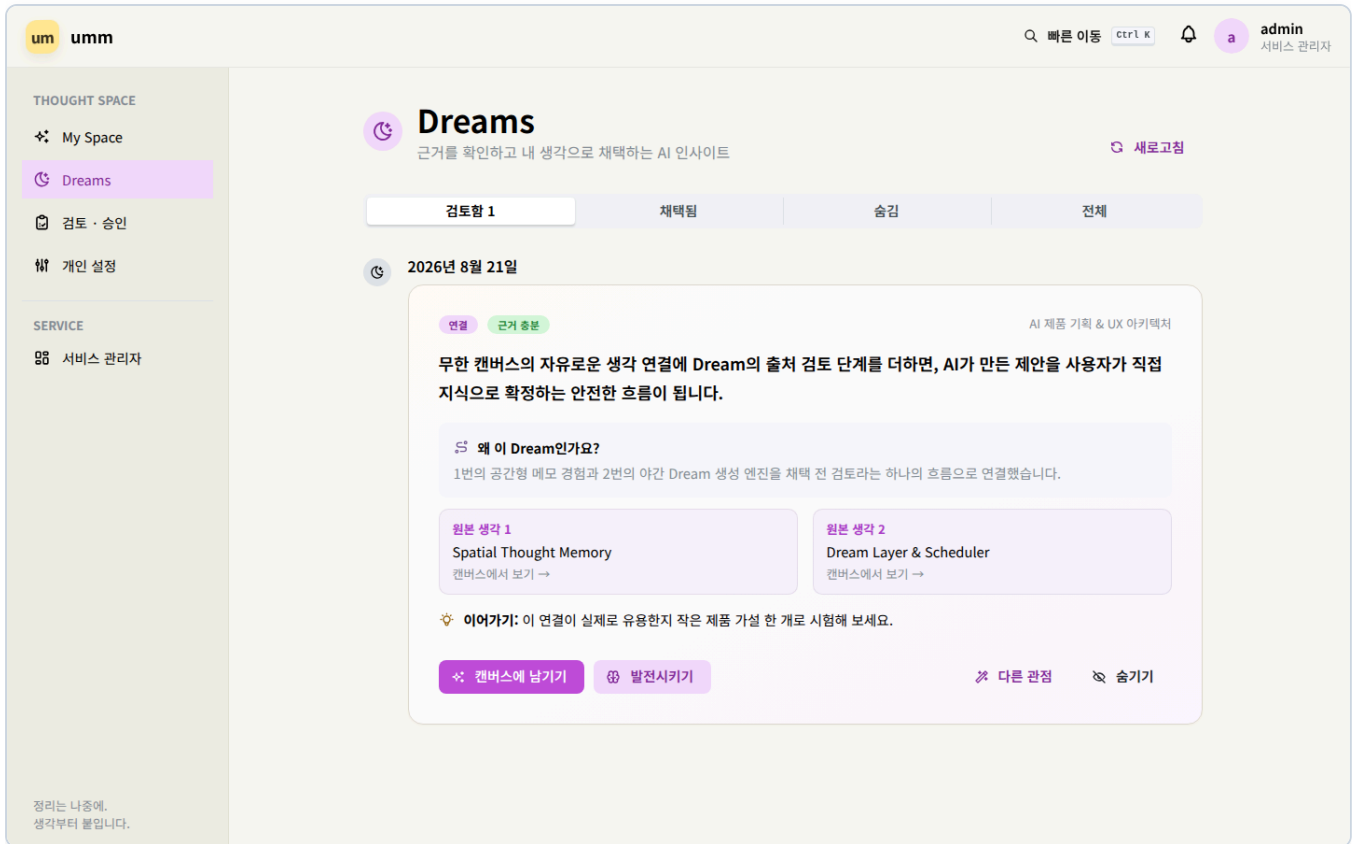
## 7. 공간 협업 및 공유 (Space Collaboration)



- 팀원 초대: 사내 사용자를 검색하여 공동 작업 공간으로 초대
- 세분화된 권한 제어:
  - 보기 (View) : 메모 조회 및 내보내기만 가능
  - 편집 (Edit) : 메모 생성, 수정, 연결선 조작 가능
  - 관리 (Manage) : 멤버 관리 및 공간 설정 제어
- 팀장 승인 연동: 관리자 검토 정책이 켜져 있을 경우 공간 공유 시 팀장 승인 단계 자동 삽입

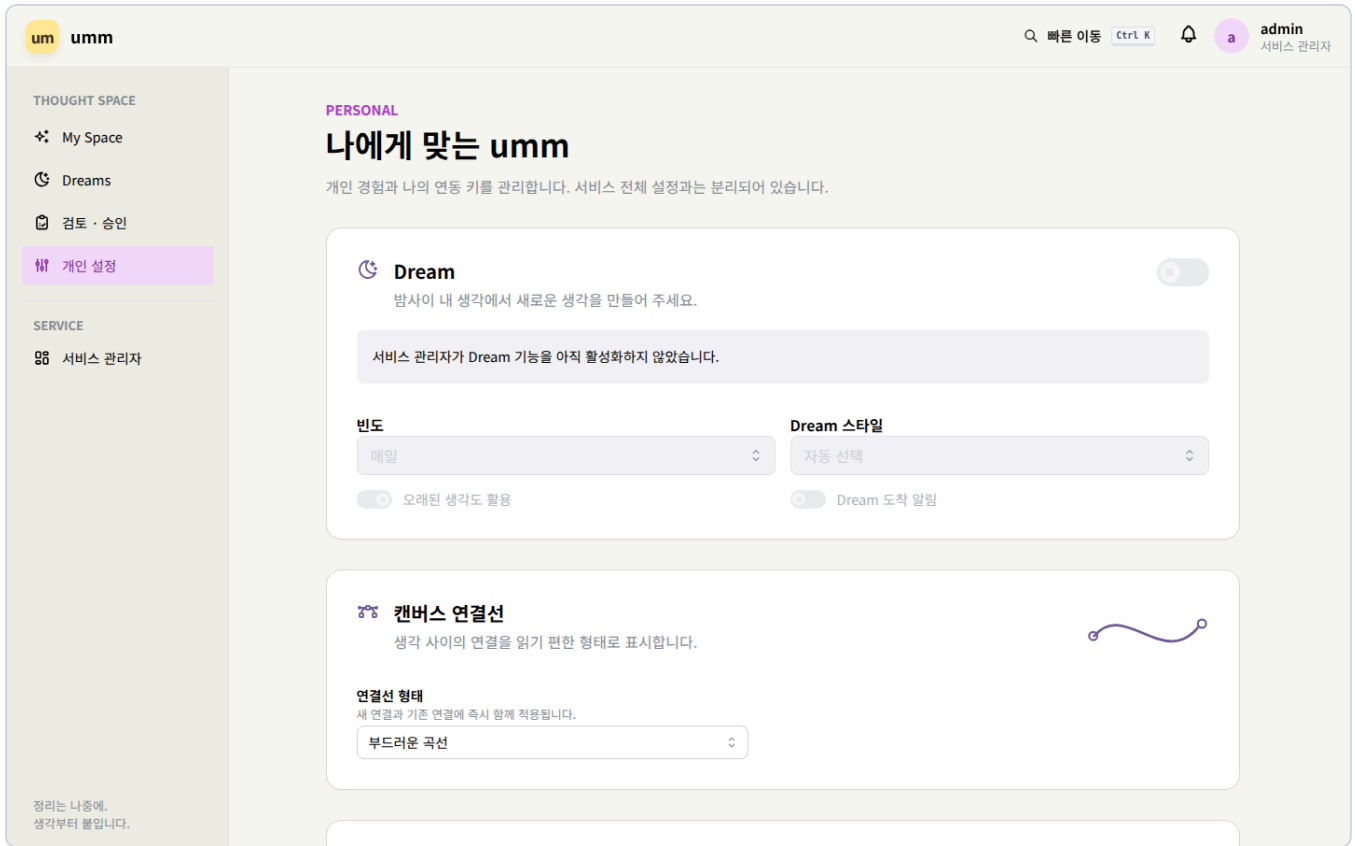


## 8. Dream 검토함 ( /dreams )



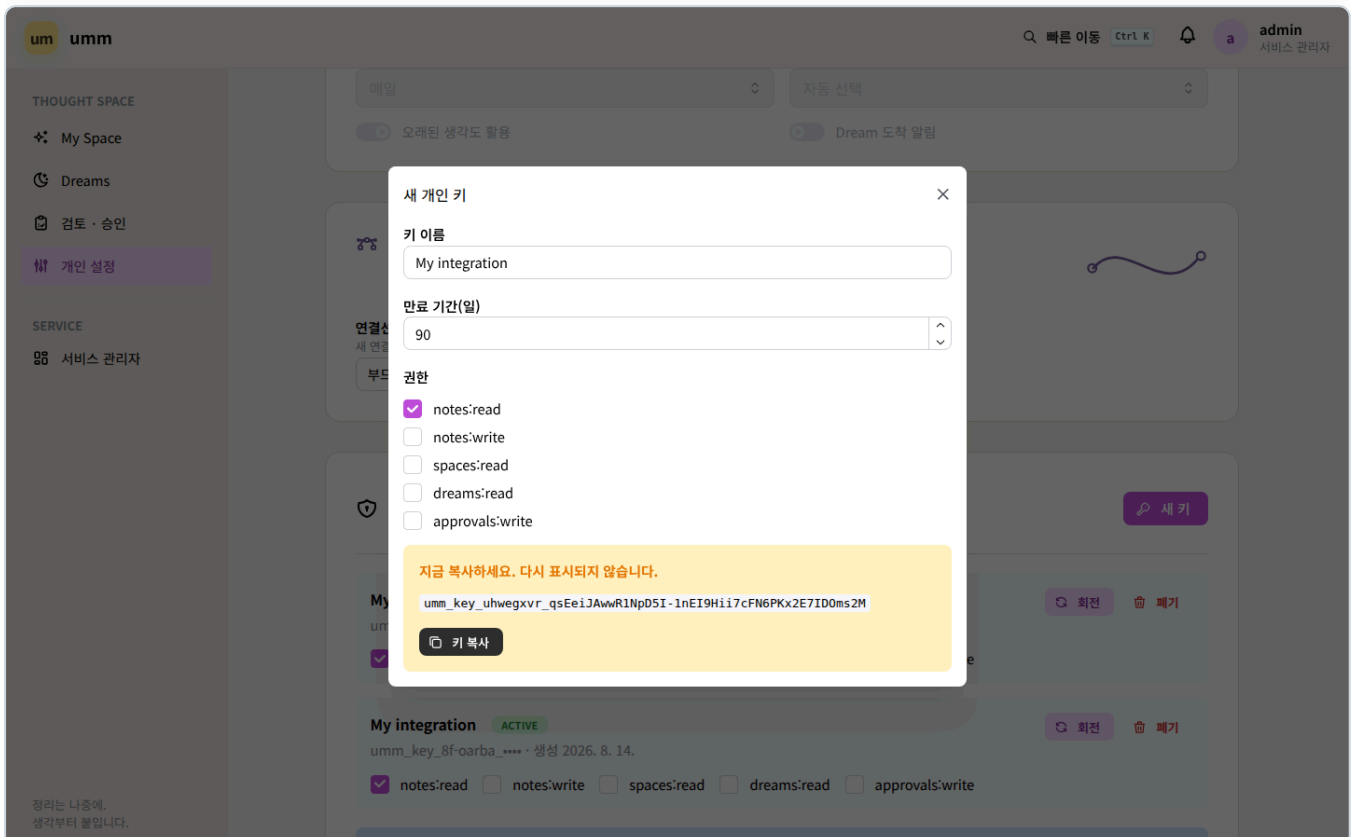
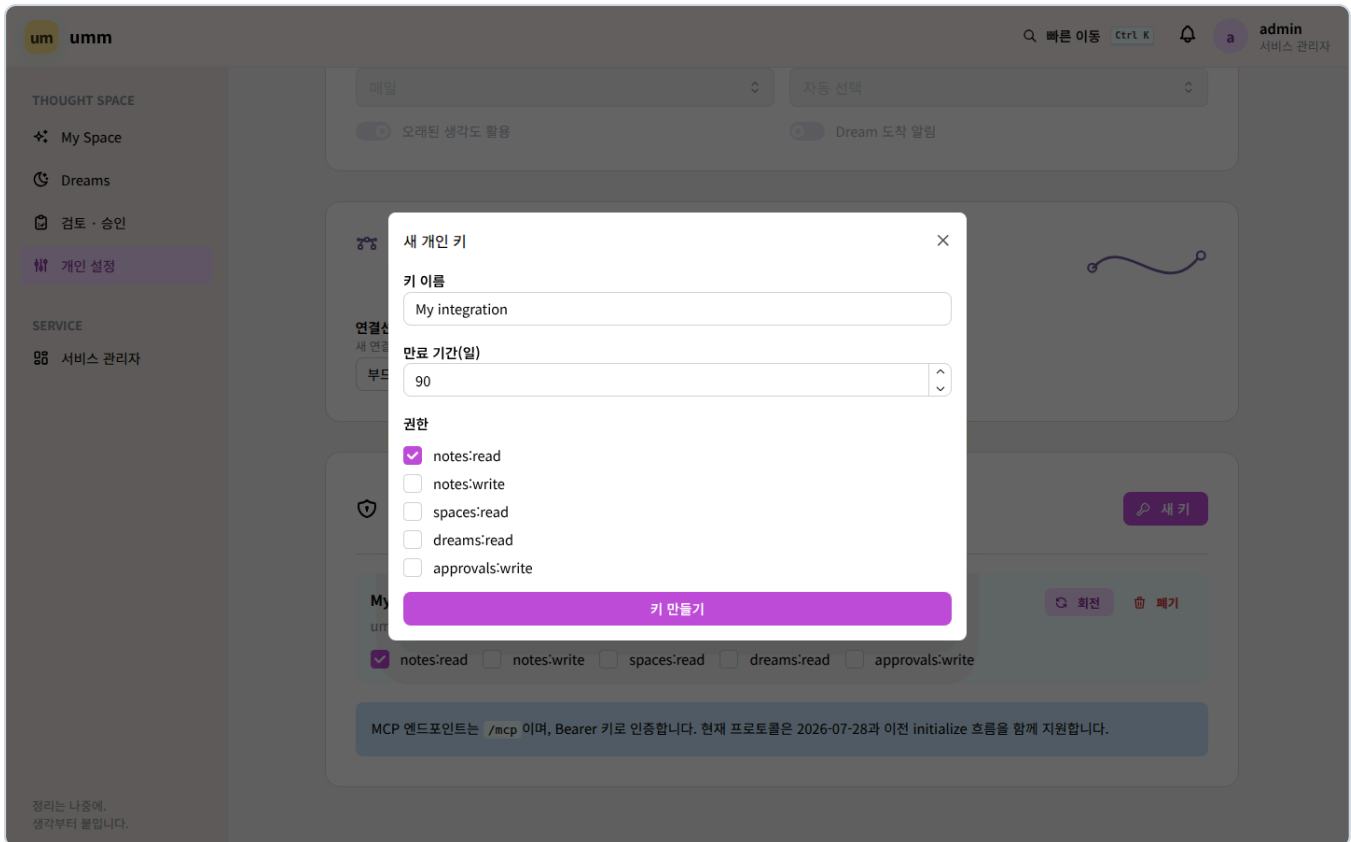
- **채택 전 후보 보관:** Dream Scheduler가 만든 관점은 검토함에 먼저 도착하며, 사용자가 채택하기 전에는 캔버스와 연결선을 변경하지 않음
- **근거와 설명:** 연결/질문/확장 등의 유형, 설명형 품질 배지, 생성 이유, 실제 원본 메모를 함께 표시
- **캔버스 안착:** **캔버스에 남기기** 를 누를 때만 라벤더 포스트잇과 원본 생각 연결선을 원자적으로 생성
- **다른 관점과 발전:** 같은 근거로 중복되지 않는 후보를 다시 만들거나 확장/반대 관점/실행 항목으로 발전하며, AI Assist와 자동 생성까지 외부 AI 호출 동안 원본·현재 공유권한을 하나의 접근 lease로 고정. 채택 후 발전 결과도 메모와 연결선을 한 트랜잭션으로 저장
- **정확한 노출·알림 이동:** 카드가 화면에 50% 이상 실제 보일 때만 노출로 집계하고, Dream 도착 알림을 누르면 해당 카드로 바로 이동
- **현재 공유 범위만 표시:** 공유 공간에서 만든 개인 Dream도 현재 owner/member 권한이 있을 때만 Today·검토함에 본문·공간명·원본을 표시하며, 공유가 회수되면 기존 Dream ID의 피드백·채택·재생성·발전을 함께 닫음
- **구체적 피드백:** 뻔함, 무관함, 사실 오류, 반복은 스타일 선호에 반영하고, 과도한 빈도 피드백은 생성 주기를 자동 완화

## 9. 개인화 설정 ( /settings )



- **Dream 개인화 옵션:**
  - Dream 생성 빈도 (매일, 주 3회, 주 1회)
  - 스타일 선호 (자동, 연결 중심, 질문 중심, 확장 중심, 자유)
  - 오래된 생각 활용 여부 및 Dream 일시 중지 (오늘 / 3일 / 일주일)
- **연결선 형태 선택:** 부드러운 곡선(Bezier), 둥근 꺾은선(Smoothstep), 직선(Straight) 실시간 미리보기 및 변경

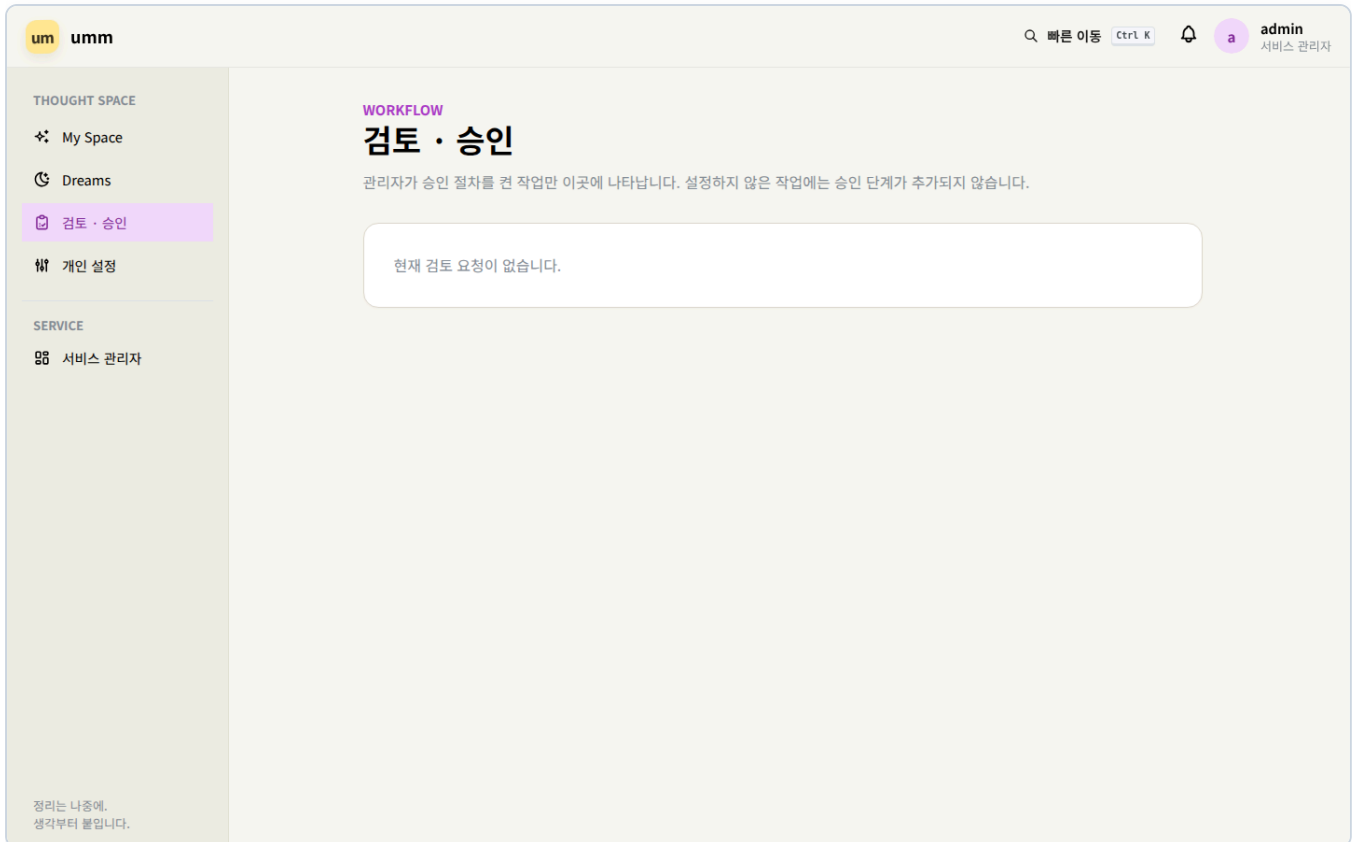
## 10. 개인 API · MCP 키 관리



- 최소 권한 Scoped API Key: 필요한 권한( `spaces:read` , `notes:read` , `notes:write` , `ai:assist` 등)만 선택하여 발급
- 일회성 Secret 표시: 발급 시 1회만 노출되는 보안 토큰

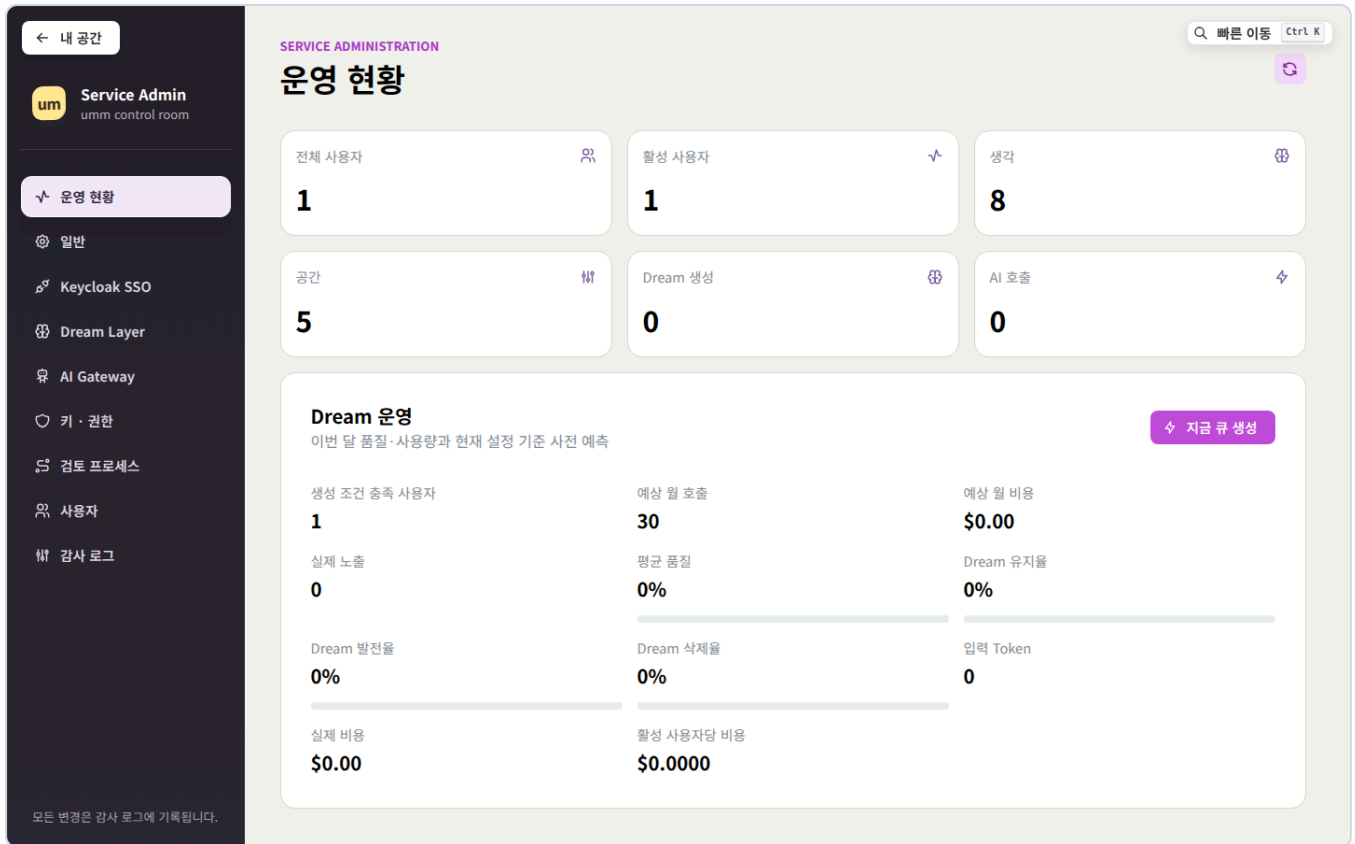
- **무중단 키 회전 (Zero-Downtime Rotation):** 설정된 중첩 시간(예: 24시간) 동안 기존 키와 신규 키를 동시 지원하여 서비스 중단 없는 안전한 키 교체. 보안 난수 생성이 실패하면 새 키나 짧은 대체 키를 저장하지 않고 기존 상태를 그대로 유지

## 11. 검토 및 승인 대기열 ( /approvals )



- **작업별 조건부 승인:** 공간 공유 및 외부 내보내기 요청 목록 조회
- **팀장/관리자 결정:** 요청 사유 확인 후 의견(Comment)과 함께 승인(Approve) 또는 반려(Reject) 처리

## 12. 서비스 관리자: 운영 현황 ( /admin/overview )



- **KPI 지표 요약:** 전체 사용자, 활성 사용자, 생각 수, 공간 수, Dream 생성 수, AI 호출 수
- **Dream 운영 예측 및 비용 분석:** 예상 월 호출량과 비용, 검토 수, 채택률, 유의미 활용률, 발전/숨김률, 채택 Dream당 비용
- **즉시 큐 생성 (Manual Trigger):** 야간 스케줄러 대기 없이 즉시 Dream 분석 작업 큐 실행

### 13. 서비스 관리자: 일반 설정 ( /admin/general )

← 내 공간

um

Service Admin

umm control room

운영 현황

일반

Keycloak SSO

Dream Layer

AI Gateway

키 · 권한

검토 프로세스

사용자

감사 로그

모든 변경은 감사 로그에 기록됩니다.

SERVICE ADMINISTRATION

빠른 이동 Ctrl K

일반

서비스 기본 정보

재시작 없이 적용되며 로그인 화면과 서비스 전반에 반영됩니다.

서비스 이름

umm

공개 URL

OIDC Callback과 Origin 검증에 사용됩니다.

http://localhost:8080

세션 유지 시간

24 시간

서비스 시간대

Asia/Seoul

모든 변경사항이 저장되었습니다.

저장

- 서비스 기본 정보: 서비스 명칭, 공개 URL(Public URL), 세션 유지 시간(1~720시간), 서비스 시간대(IANA Timezone) 구성
- 무중단 즉시 반영: 서버 재시작 없이 저장 즉시 전체 서비스에 적용

## 14. 서비스 관리자: Keycloak SSO ( /admin/oidc )

← 내 공간

um Service Admin  
umm control room

운영 현황

일반

Keycloak SSO

Dream Layer

AI Gateway

키 · 권한

검토 프로세스

사용자

감사 로그

모든 변경은 감사 로그에 기록됩니다.

SERVICE ADMINISTRATION

Keycloak SSO

빠른 이동 Ctrl K

↺

Keycloak SSO · OIDC

연결 시험

Issuer URL, Client ID, Client Secret만으로 Discovery를 통해 자동 연결합니다.

Keycloak SSO 활성화

Issuer URL  
https://keycloak.internal/realm/umm

Client ID

Client Secret

관리자 그룹/역할  
umm-admin

팀장 그룹/역할  
umm-team-lead

Keycloak Confidential Client에서 Standard Flow를 켜고 Callback을 <http://localhost:8080/api/v1/auth/oidc/callback>으로 정확히 등록하세요.

모든 변경사항이 저장되었습니다.

저장

- **OIDC Discovery 자동 연동**: Issuer URL 입력만으로 엔드포인트 자동 탐색
- **암호화 자격증명 보관**: Client Secret을 AES-256-GCM으로 암호화 저장
- **그룹 및 역할 매핑**: 사내 Keycloak 그룹/역할을 umm의 `admin`, `team_lead`, `user` 로 자동 매핑
- **원클릭 연결 시험**: 실시간으로 Keycloak 서버와의 OIDC 핸드셰이크 검증

## 15. 서비스 관리자: Dream Layer ( /admin/dream )

← 내 공간

um

Service Admin

umm control room

📈 운영 현황

🔗 일반

🔑 Keycloak SSO

**🔗 Dream Layer**

🔗 AI Gateway

🔑 키 · 권한

🔄 검토 프로세스

👤 사용자

📄 감사 로그

모든 변경은 감사 로그에 기록됩니다.

SERVICE ADMINISTRATION

**Dream Layer** 저장 안 됨

🔍 빠른 이동 Ctrl K

🔄

**Dream Settings**

좋은 Dream이 없으면 생성하지 않는 것을 기본 원칙으로 합니다.

☐ Dream 기능

생성 시간

02:00 AM

🕒

사용자당 Dream

1 장

↕

최근 분석 범위

7 일

↕

Model

월 사용자 호출 제한

30

↕

☐ 자동 생성

생성 주기

매일

↕

최소 메모

3 개

↕

최대 Context 메모

20 개

↕

최대 응답 Token

주문 토큰을 포함한 최대 출력 한도입니다.

262,144

↕

4K 16K 64K 128K 256K

☒ 사용자 개별 OFF 허용

☐ Dream 도착 알림 허용

저장되지 않은 변경사항이 있습니다.

저장

하세요.

- 스케줄 및 빈도 제어: 자동 생성 시간(기본 02:00), 주기(매일/평일/주말/요일별/N일 간격)
- 256K Context Window 토큰 한도 제어: 모델 사양에 맞춰 4K부터 256K까지 토큰 슬라이더 설정
- 품질 기준선(Quality Threshold) & Quiet Mode: 가치가 높은 경우에만 선별적으로 Dream을 생성하는 Quiet Mode 및 노출 최소 점수 제어

16



## 16. 서비스 관리자: AI Gateway ( [/admin/ai\\_gateway](/admin/ai_gateway) )

← 내 공간

um

Service Admin

umim control room

🏠 운영 현황

⚙️ 일반

🔑 Keycloak SSO

🌐 Dream Layer

**🔗 AI Gateway**

🔐 키 · 권한

🔄 검토 프로세스

👤 사용자

📄 감사 로그

모든 변경은 감사 로그에 기록됩니다.

SERVICE ADMINISTRATION

AI Gateway

빠른 이동 Ctrl K

🔄

**내부 AI Gateway**

OpenAI 호환 Chat Completions 엔드포인트를 사용합니다. 외부 연결 없이 내부 모델 서버를 지정할 수 있습니다.

Base URL

http://llm-gateway.internal:8000

API Key

👁

Timeout

긴 추론 모델은 충분한 시간을 지정하세요.

45 초

↕

재시도

2

↕

입력 \$ / 1M token

0

↕

출력 \$ / 1M token

0

↕

AI 로그 보존

90 일

↕

Prompt Version

dream-v1

모든 변경사항이 저장되었습니다.

저장

- 내부 OpenAI 호환 Gateway 연동: Base URL, API Key, Timeout(5~1800초), 재시도 횟수 지정
- 비용 산정 및 데이터 보존: 토큰당 단가(\$/1M tokens), AI 로그 보존 주기(기본 90일), 원문 프롬프트 암호화 저장 옵션

## 17. 서비스 관리자: 키 · 권한 체계 ( /admin/security )

← 내 공간

Service Admin  
umm control room

운영 현황  
일반  
Keycloak SSO  
Dream Layer  
AI Gateway  
**키 · 권한**  
검토 프로세스  
사용자  
감사 로그

모든 변경은 감사 로그에 기록됩니다.

SERVICE ADMINISTRATION

### 키 · 권한

개인 키 권한 체계  
사용자가 자신의 키에 부여할 수 있는 권한과 회전 정책입니다.

허용 API/MCP Scopes

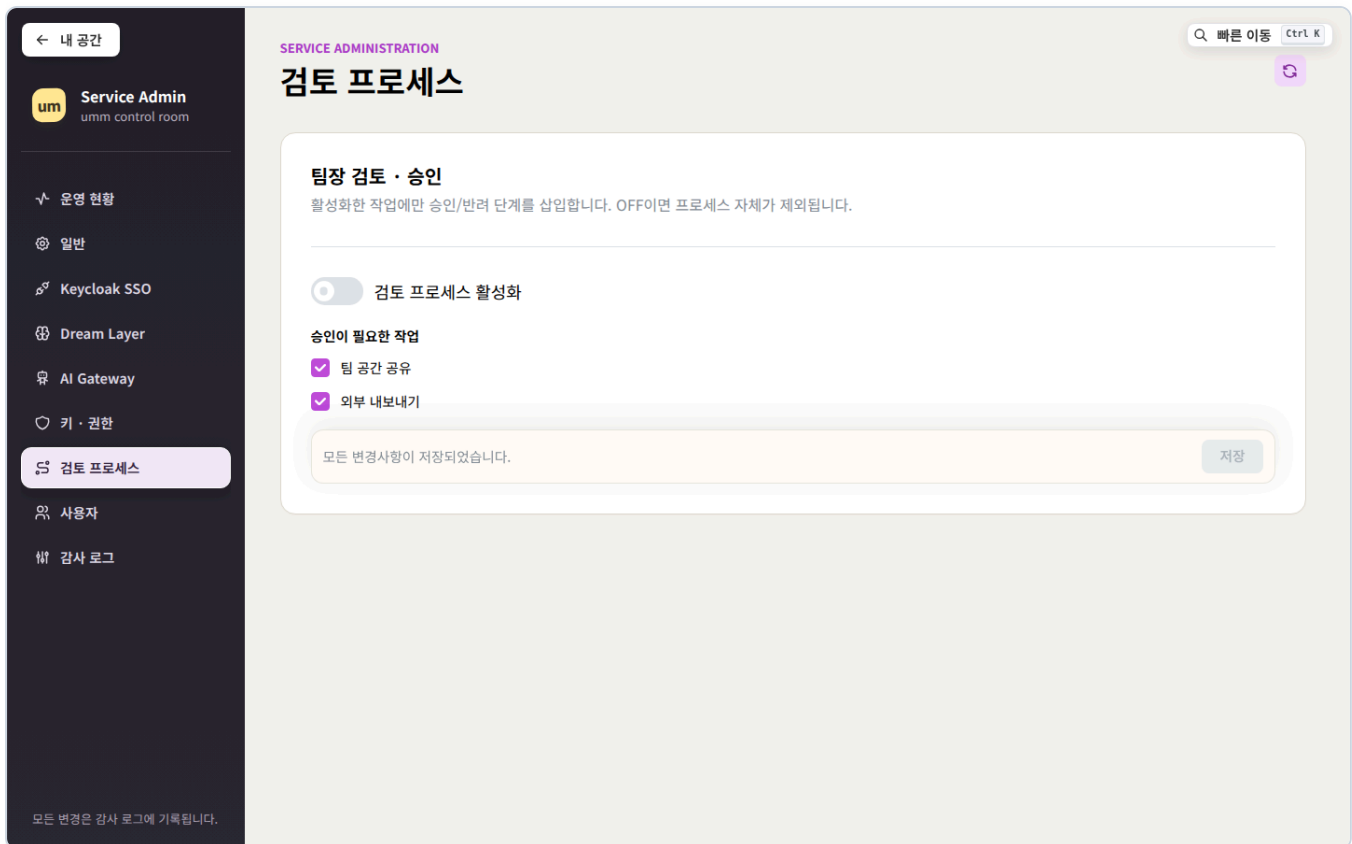
notes:read × notes:write × spaces:read × dreams:read × approvals:write ×

기본 키 만료: 90 일  
회전 중첩 시간: 24 시간

모든 변경사항이 저장되었습니다. 저장

- **허용 API/MCP Scopes 제어**: 일반 사용자가 발급 가능한 권한 태그 화이트리스트 관리
- **키 수명 주기 정책**: 기본 키 유효기간(일) 및 회전 시 중첩 시간(시간) 설정
- **롤링 업그레이드 설정 보존**: 구버전 관리자 화면이 새 로그인·API·AI 한도 필드를 생략해도 최신 저장값에서 생략 항목만 원자적으로 병합하며, 명시한 `0` 은 유지하고 `null` 은 거부

## 18. 서비스 관리자: 검토 프로세스 ( </admin/workflow> )



- 작업별 승인 프로세스 On/Off: 팀 공간 공유, 외부 내보내기 중 승인이 필요한 작업 선택

## 19. 서비스 관리자: 사용자 관리 ( /admin/users )

The screenshot shows the 'Service Admin' interface for user management. On the left is a dark sidebar with navigation links: '내 공간', '운영 현황', '일반', 'Keycloak SSO', 'Dream Layer', 'AI Gateway', '키 · 권한', '검토 프로세스', '사용자' (highlighted), and '감사 로그'. The main content area is titled 'SERVICE ADMINISTRATION' and '사용자'. It includes a search bar '빠른 이동 Ctrl K' and a refresh button. A message states: 'Keycloak 그룹 매핑 또는 여기에서 역할과 팀을 변경할 수 있습니다.' Below this is a table with columns: '사용자', '역할', '팀', and '상태'. The table contains one entry for 'admin' with role '관리자', team '팀 없음', and status 'ON'. A footer note says '모든 변경은 감사 로그에 기록됩니다.'

| 사용자              | 역할  | 팀    | 상태 |
|------------------|-----|------|----|
| admin<br>admin · | 관리자 | 팀 없음 | ON |

- 사내 계정 통합 관리: 사용자별 역할( `user` , `team_lead` , `admin` ), 소속 팀명, 계정 활성화/비활성 스위치 제어

## 20. 서비스 관리자: 불변 감사 로그 ( /admin/audit )

← 내 공간

um

Service Admin

umim control room

🏠 운영 현황

👤 일반

🔑 Keycloak SSO

🌐 Dream Layer

🔗 AI Gateway

🔑 키 · 권한

📋 검토 프로세스

👤 사용자

📋 감사 로그

모든 변경은 감사 로그에 기록됩니다.

SERVICE ADMINISTRATION

감사 로그

🔍 빠른 이동

Ctrl K

| 시각                      | 행위자   | 작업               | 대상                                             |
|-------------------------|-------|------------------|------------------------------------------------|
| 2026. 8. 14. 오후 7:44:29 | admin | API_KEY.CREATE   | api_key · 04408cc1-0fd1-4d9b-8af9-551bad889c72 |
| 2026. 8. 14. 오후 7:44:13 | admin | NOTE.CREATE      | note · fdec7208-81b4-4c9e-b72c-a093ff5eb735    |
| 2026. 8. 14. 오후 7:44:13 | admin | NOTE.CREATE      | note · fdd2a826-122c-4a5f-ab3b-fc8953b50992    |
| 2026. 8. 14. 오후 7:44:13 | admin | NOTE.CREATE      | note · 8ff0db4e-dc4a-4b3c-807a-d3ce262823a7    |
| 2026. 8. 14. 오후 7:44:13 | admin | NOTE.CREATE      | note · 0daf2b40-3273-4c43-9c42-4617ca3ef6e4    |
| 2026. 8. 14. 오후 7:44:13 | admin | SPACE.CREATE     | space · 292fed54-8eb5-4116-8cb5-de47c4c1df7e   |
| 2026. 8. 14. 오후 7:44:13 | admin | SPACE.CREATE     | space · 394ba99f-5488-488d-b4a5-6f0590779d90   |
| 2026. 8. 14. 오후 7:44:12 | admin | AUTH.LOCAL.LOGIN | user · 4dcba2b5-f79b-4f3d-9cf4-f775a624a74f    |
| 2026. 8. 14. 오후 7:43:43 | admin | API_KEY.CREATE   | api_key · 78d66fdd-cdd9-469e-b76e-9df12c4605b2 |
| 2026. 8. 14. 오후 7:43:35 | admin | NOTE.CREATE      | note · 13ef50f1-c223-448e-ac25-3552aab24efd    |
| 2026. 8. 14. 오후 7:43:35 | admin | NOTE.CREATE      | note · 0be07091-9fa6-4a4d-ae44-acedef347b29    |
| 2026. 8. 14. 오후 7:43:35 | admin | NOTE.CREATE      | note · 18eea206-8f57-45be-832a-273a02e3e316    |
| 2026. 8. 14. 오후 7:43:35 | admin | NOTE.CREATE      | note · c86028b5-f369-415e-9154-3a16e0b40295    |
| 2026. 8. 14. 오후 7:43:35 | admin | SPACE.CREATE     | space · 49311534-7d0b-44bc-9f67-11be6ee6fd8f   |

- 추가 전용(Append-only) 감사 추적: 시각, 행위자, 작업 구분(Action), 대상 리소스(Resource ID)를 위변조 없이 기록

## 21. 오늘의 리뷰 ( /today )

- 집중 검토함: 다시 볼 날짜가 된 생각, 오래 검토하지 않은 생각, 연결되지 않은 생각, 대기 중인 Dream, 최근 댓글을 한 화면에 모읍니다.
- 맥락형 온보딩: 공간 생성·생각 작성·연결·Dream 확인 단계가 실제 사용 상태에 따라 자동 완료됩니다.
- 사용자별 다시 보기·고정: 공유 생각에서도 서로의 상태를 덮어쓰지 않고 검토 완료, 1~365일 미루기, 중요 항목 고정을 관리합니다.
- 독립적인 활동 요약 설정: 개인 설정에서 “리뷰 요약에 활동 포함”을 꺼도 최근 협업 활동만 숨기며, 고정·기한 도래·오래된 생각의 검토 카드는 그대로 유지합니다.
- 권한·삭제 경계: 현재 접근 가능한 공간의 삭제되지 않은 생각에 속한 활동만 표시합니다.

## 22. 협업·검색·오프라인 신뢰성

- 하이브리드 검색: 접근 가능한 전체 메모와 긴 본문 뒤쪽의 키워드 일치를 보존하면서 로컬 의미 유사도를 결합하고 공간·종류·수정 시각 필터, 점수와 추천 이유를 제공합니다.
- 백링크·댓글·멘션: 실제 연결선 방향을 확인하고 포스트잇 안에서 댓글을 남기며 @username 으로 공간 멤버를 알립니다. 댓글 작성 transaction은 현재 멤버십을 끝까지 잠그고, 작성자도 현재 공간 접근권한이 있을 때만 자신의 댓글을 삭제할 수 있습니다. 생각이 삭제되면 보관한 댓글 ID로 해결·재개·삭제 이벤트를 만들 수 없고 comment-mutation-forbidden 으로 종료하며 기존 댓글·멘션 알림도 목록과 unread count에서 숨깁니다.

- **오프라인 큐:** 연결이 끊기면 변경을 장치에 보관하고 다시 연결될 때 먹등 키로 재전송하며, 영구 거부된 요청은 사유를 알리고 그 항목만 제거한 뒤 다음 변경을 계속 처리합니다. 권한 회수 뒤의 댓글 해결·삭제도 terminal type으로 구분해 독립적인 후속 변경을 막지 않습니다. 업그레이드 도중 구버전 탭이 레거시 큐에 늦게 기록한 변경도 기존 계정 큐와 잠금 아래 병합한 뒤 이전 키를 정리하므로 사라지지 않습니다.
- **충돌 병합:** 다른 위치에서 먼저 저장한 버전이 있으면 내 내용과 서버 내용을 나란히 비교해 선택·병합합니다.
- **접근 가능한 대체 보기:** 키보드 화살표 이동, 명확한 focus ring, 최소 터치 영역, reduced-motion, 선형 생각 목록을 지원합니다.

## 23. 개인 서명 웹훅 ( /settings )

- `note.*`, `comment.*`, `member.*`, `dream.accepted` 등 원하는 이벤트를 HTTPS endpoint로 전달합니다.
- HMAC-SHA256 signing secret은 생성·회전 직후 한 번만 표시합니다.
- 도메인 변경과 PostgreSQL outbox를 원자적으로 커밋해 재시작 뒤에도 이어 보내며, 사설·예약 IP SSRF 차단, 세 번 재시도, 연속 10회 실패 시 자동 중지를 적용합니다. 다국어 오류는 유효한 UTF-8 rune 경계에서 제한해 실패 상태와 자동 중지 횟수를 빠짐없이 기록합니다.
- at-least-once 전달 시도에 대비해 수신 시스템은 delivery UUID를 먹등 처리합니다.
- terminal payload는 즉시 제거하고 delivery metadata는 30일 뒤 정리합니다.

## 24. 관리자 AI 평가·키 회전·관측성

- **AI 평가 세트:** 입력 생각, 기대 단어, 금지 단어로 Dream grounding·품질 회귀를 실행하고 점수·모델·prompt version을 기록합니다.
- **Master-key 회전:** primary/fallback keyring 상태와 회전 대기·읽기 실패를 확인하고 저장된 암호문을 트랜잭션으로 다시 암호화합니다. `enc:` wrapper 이전에 저장된 raw v1 AI prompt도 현재 primary key의 wrapper·v2 형식으로 회전한 뒤에만 pending이 0이 됩니다. OIDC·AI Gateway의 마스킹 설정 저장은 회전과 같은 설정 lock 뒤 최신 secret을 병합해 이전 화면의 동시 저장에도 새 암호문을 보존합니다.
- **운영 지표:** 댓글·온보딩·웹훅 실패·AI eval 결과와 HTTP request/latency를 관리 화면 및 Prometheus에서 확인합니다.

## 25. 언어 · 테마 · 가져오기 (v0.8.0)

- **한국어 / English:** 프로필 메뉴에서 언어를 바꾸면 화면 전체가 즉시 전환됩니다. 선택은 계정에 저장되어 다른 브라우저에서도 이어집니다. 언어·테마 부분 저장이 동시에 겹쳐도 각 선택을 원자적으로 합쳐 서로 되돌리지 않습니다. 번역이 없는 문구는 한국어 원문으로 표시되므로 화면이 비어 보이는 일이 없습니다.
- **밝게 / 어둡게 / 시스템 설정:** 로그인하면 계정의 테마를 현재 탭의 활성 theme provider에 즉시 적용하고, 시스템 설정은 자동 모드로 복원합니다. 첫 페인트 전에 테마가 결정되어 어두운 화면으로 들어올 때 흰 화면이 번쩍이지 않으며, 포스트잇은 두 테마에서 모두 종이색을 유지합니다.
- **마크다운 가져오기:** 내보내기 메뉴에서 마크다운 파일이나 붙여넣은 텍스트를 `#` 제목·`---` 구분선·빈 줄 기준으로 나눠 각각 하나의 생각으로 캔버스에 붙입니다(한 번에 최대 200개). 200개를 넘으면 실제 개수를 안내하고 가져오기를 시작하지 않으므로 201번째 이후 원문도 편집기에 그대로 남습니다. 부분 실패 시 성공 항목은 유지하고 실패 항목만 편집기에 남겨 다시 시도합니다.
- **모바일 공유 타겟과 안전한 앱 셀:** 설치형 PWA로 추가하면 다른 앱의 공유 시트에 umm이 나타나고, 공유한 내용이 빠른 입력창에 채워집니다. 서비스 워커는 HTML 탐색 응답만 오프라인 앱 셀로 갱신해 manifest·asset JSON·아이콘을 직접 열어도 다음 오프라인 화면이 해당 정적 파일로 바뀌지 않습니다. Content hash가 붙은 bundle만

장기 immutable로 캐시하고 고정 manifest·service worker·아이콘은 재검증해 새 릴리스의 바로가기와 앱 메타데이터를 오래된 값으로 고정하지 않습니다.

- **키보드 편집:** 캔버스에서 **Tab** 으로 생각 사이를 이동하고 **Enter** 로 편집을 시작하며 **Esc** 로 빠져나옵니다.

## 26. 규모와 남용 방지 (v0.8.0)

- **푸시 기반 실시간 협업:** 공간을 열어 둔 사람마다 초당 폴링하던 구조를 PostgreSQL **LISTEN/NOTIFY** 팬아웃으로 바꿨습니다. 유휴 상태의 데이터베이스 비용이 0이고, 변경은 즉시 도착합니다. 상한 1~2의 작은 pool에서는 모든 연결을 request에 남기도록 전용 listener를 끄고 1초 안전 폴링으로 자동 전환하며, 상한 3부터 두 request 연결을 남긴 채 listener를 시작합니다. 실행 중 listener가 끊기거나 복구되면 상태 전환이 열린 SSE를 즉시 깨워 긴 safety deadline을 기다리지 않고 폴링 주기를 다시 맞춥니다.
- **인덱스를 타는 검색:** 키워드 조건을 **pg\_trgm** GIN 인덱스가 사용될 수 있는 형태로 다시 작성했습니다.
- **선택적 게이트웨이 임베딩:** 관리자가 임베딩 모델을 지정하면 의미 검색 품질이 올라가고, 비워 두면 지금까지처럼 완전 오프라인으로 동작합니다. 모델명과 Gateway endpoint fingerprint를 함께 벡터 공간으로 식별해 같은 모델명을 쓰는 제공자로 주소를 바꿔도 기존 벡터를 점진적으로 다시 만듭니다. 설정 변경 전에 시작한 원격 응답과 장애 뒤의 전체 로컬 정규화 pass는 새 Gateway 벡터를 덮어쓰지 못합니다. 원격 장애나 한 batch 안의 vector 차원 불일치 시에는 비교 집합 전체를 한 로컬 벡터 공간으로 맞추고 5분 회로 차단으로 반복 timeout을 피합니다. 임베딩과 Dream Gateway의 오류 본문 일부는 다국어 rune를 쪼개지 않고 제한해 관리자 오류 응답과 로그가 항상 유효한 UTF-8을 유지합니다.
- **로그인 잠금과 요청 한도:** 인스턴스 간에 공유되는 로그인 잠금, 호출자별 API 한도, AI 생성의 분당·하루 한도를 관리자 화면에서 조정합니다. 같은 주소·계정의 비밀번호 검증과 실패 기록을 하나의 PostgreSQL 임계 구역에서 처리해 병렬 요청도 설정한 추측 횟수를 넘지 않습니다.
- **로그인한 기기:** 개인 설정에서 다른 로그인을 확인하고 즉시 종료할 수 있습니다.
- **응답별 CSP nonce:** 스크립트 실행을 응답마다 새로 만드는 nonce로 고정해, 주입된 스크립트가 같은 출처를 가리켜도 실행되지 않습니다.

# umm 사용자 실무 가이드 (User Guide)

umm은 복잡한 폴더 트리나 문서 서식에 얽매이지 않고, 머릿속 생각을 자유로운 2차원 공간 위에 직관적으로 펼치고 발전시킬 수 있도록 돕는 서비스입니다.

## 1. 공간(Space) 관리

- **공간 개념:** 프로젝트, 아이디어 주제, 업무 영역별로 독립된 무한 캔버스입니다.
- **공간 전환 & 검색:**
  - 상단 툴바의 공간 이름 버튼(예: **AI 제품 기획 & UX 아키텍처**)을 클릭하여 공간 목록을 열람합니다.
  - 검색창에 키워드를 입력하여 원하는 공간으로 빠르게 이동합니다.
- **새 공간 만들기:**
  - 공간 드롭다운 하단의 **새 공간 만들기** 또는 **공간 관리**를 선택합니다.
  - 공간 이름을 입력하고 Enter 또는 **만들기** 버튼을 누릅니다.
- **공간 팀원 공유:**
  - 상단 툴바의 **공간 공유 (IconShare)** 버튼을 클릭합니다.
  - 팀원의 아이디를 입력하고 권한(**보기**, **편집**, **관리**)을 선택한 후 **초대** 합니다.

## 2. 생각 포스트잇 작성 및 편집

### 포스트잇 생성 4가지 방법

1. **캔버스 빈 공간 더블클릭:** 마우스 커서가 위치한 지점에 빈 포스트잇이 즉시 생성됩니다.
2. **단축키 **N**:** 포스트잇 입력 필드에 포커스되어 타이핑 즉시 새 생각이 붙습니다.
3. **단축키 **/**:** 상단 생각 검색 필드로 즉시 이동합니다.
4. **하단 Quick Capture 바:** 화면 하단 캡처 바에 생각을 입력하고 Enter를 누르면 화면 중앙에 즉시 배치됩니다.

### 포스트잇 조작 및 색상

- **내용 입력 & 자동 저장:** 메모장을 클릭하여 자유롭게 내용을 작성하면, 별도의 저장 버튼 없이 수백 밀리초 내에 자동 저장됩니다.
- **7가지 시맨틱 색상 변경:**
  - 메모 우측 상단의 **점 세 개 (IconDots)** 메뉴 → **색상** 선택
  - **노랑 (Yellow)**, **파랑 (Blue)**, **보라 (Purple)**, **라벤더 (Lavender)**, **초록 (Green)**, **빨강 (Red)**, **회색 (Gray)** 중 선택
- **크기 조절 & 회전:** 메모를 클릭하면 모서리에 핸들이 표시되며, 드래그하여 자유롭게 크기를 늘리거나 줄일 수 있습니다.



- **메모 삭제:** 메모 메뉴에서 **지우기**를 선택하거나, 노드를 선택한 상태에서 **Delete** / **Backspace**를 누릅니다.

 **메모 버전 이력 및 복원**

- 메모 메뉴에서 **이전 버전 복원**을 클릭하면, 변경되기 전 과거 시점의 스냅샷으로 안전하게 롤백할 수 있습니다.

### 3. 생각 연결 및 지능형 배치

 **생각 연결선 (Edges)**

- 메모 좌우의 동그란 연결 핸들을 마우스로 드래그하여 다른 메모의 핸들에 연결합니다.
- 연결선은 부드러운 곡선(Bezier), 둥근 꺾은선(Smoothstep), 직선(Straight) 형태로 표시됩니다.

 **Thought Gravity (생각 인력)**

- 중심이 되는 메모를 하나 선택한 뒤 상단 툴바의 **Thought Gravity (IconFocusCentered)**를 클릭합니다.
- 선택한 메모와 직간접적으로 연결된 모든 생각들이 중심 메모를 기준으로 원형 궤도를 그리며 정렬됩니다.

 **의미 기반 연관 생각 (Related Thoughts)**

- 포스트잇 하단에 **관련 N** 배지가 표시되면 이를 클릭합니다.
- AI Gateway 연결 없이도 내부 의미 유사도 엔진이 연관된 생각들을 찾아 유사도 점수(%) 및 추천 사유와 함께 주변에 배치합니다.

### 4. AI 생각 발전 도구 (AI Assist)

캔버스 상단 툴바의 **AI 생각 도구 (IconBrain)**를 클릭하면 선택된 메모들을 기반으로 5가지 발전 기능을 실행할 수 있습니다:

| 도구     | 설명                                      | 활용 예시             |
|--------|-----------------------------------------|-------------------|
| 요약     | 흩어진 메모들의 핵심 결론을 명확하게 한 문장으로 압축          | 긴 브레인스토밍 메모 정리    |
| 질문 만들기 | 현재 생각에서 놓치고 있는 핵심 검토 질문 도출              | 기획 누락 사항 점검       |
| 확장     | 생각의 범위를 넓혀 새로운 적용 분야와 아이디어 제안           | 비즈니스 모델 확장        |
| 반대 관점  | 반론과 리스크, 비판적 시각을 제시                     | 보안 및 규제 리스크 사전 분석 |
| 실행 항목  | 아이디어를 당장 실행 가능한 Action Item(To-Do)으로 전환 | 스프린트 태스크 도출       |

결과가 마음에 들면 **새 생각으로 붙이기**를 눌러 캔버스에 바로 포스트잇으로 추가할 수 있습니다. 서버는 선택한 생각과 공간의 현재 접근 권한·AI 제외 상태를 외부 호출 직전에 다시 확인하고 응답이 끝날 때까지 고정합니다. 공유 회수나 제외 설정이 먼저 적용되면 해당 본문은 AI Gateway에 전달되지 않습니다.

## 5. Dream 검토 및 채택

---

- **검토함:** 왼쪽 **Dreams** 메뉴에서 밤사이 생성된 후보를 확인합니다. 자동 생성은 현재 접근 가능한 사용자 작성 생각만 원본으로 삼고, 후보는 아직 캔버스에 추가되지 않은 상태입니다.
  - **근거 확인:** **왜 이 Dream인가요?** 설명과 원본 생각 카드를 확인하고, 원본 카드를 누르면 해당 메모로 바로 이동합니다.
  - **채택:** **캔버스에 남기기** 를 누르면 현재 공간 편집권한을 transaction 끝까지 확인한 뒤 Dream 메모와 원본 생각 연결선이 함께 만들어집니다.
  - **다른 관점:** 같은 원본 생각을 유지하면서 최근 Dream과 겹치지 않는 다른 결론을 요청합니다.
  - **발전시키기:** Dream을 더 구체적으로 확장하거나, 반대 관점에서 검토하거나, 실행 항목으로 바꿉니다. 서버는 외부 AI 호출이 끝날 때까지 Dream과 원본 공간의 현재 접근권한을 고정하므로 공유 회수와 요청이 겹치면 둘 중 먼저 시작된 작업 순서가 보장됩니다. 채택한 Dream의 발전 결과를 남기면 원본 Dream 옆에 새 메모와 연결선이 함께 저장되며, 네트워크 재시도에도 중복되지 않습니다.
  - **도착 알림:** 상단 종 모양 알림에서 Dream을 누르면 읽음 처리 후 해당 검토 카드로 바로 이동합니다. 카드는 화면에 실제 보였을 때만 노출로 집계됩니다.
  - **공유 회수:** 공유 공간의 Dream은 현재 그 공간을 볼 수 있을 때만 Today와 검토함에 표시됩니다. 공간에서 제거되면 파생 내용과 원본 카드가 숨겨지고 이전 주소나 ID로 피드백·채택·재생성·발전할 수 없습니다.
  - **숨김 피드백:** 뻔함, 관련 없음, 사실 오류, 반복은 이후 자동 스타일 선호에 반영됩니다. **너무 자주 와요** 를 고르면 생성 빈도가 **매일 → 주 3회 → 주 1회** 순서로 낮아지고, 이미 주 1회라면 7일 동안 쉽니다.
  - **민감 정보 제외:** 메모의 점 세 개 메뉴에서 **Dream 분석에서 제외** 를 선택하거나, 공간 관리에서 **AI Dream 분석** 을 끌 수 있습니다. 제외한 내용은 AI Assist에도 전달되지 않습니다.
-

## 6. 캔버스 단축키 일람표

| 단축키                | 기능            | 설명                                   |
|--------------------|---------------|--------------------------------------|
| 더블클릭               | 메모 생성         | 캔버스 빈 곳에 즉시 포스트잇 생성                  |
| N                  | Quick Capture | 하단 새 생각 입력창으로 포커스                    |
| /                  | 생각 검색         | 상단 캔버스 메모 검색창으로 이동                   |
| Cmd + F            | 생각 검색         | 캔버스 메모 검색창 열기                        |
| F                  | 캔버스 맞춤        | 모든 메모가 한눈에 들어오도록 줌 조정 (Fit View)     |
| Cmd + A            | 전체 선택         | 캔버스 안의 모든 메모 선택                      |
| Delete / Backspace | 메모 삭제         | 선택된 메모 일괄 삭제                         |
| Cmd + Z            | 위치 Undo       | 메모 이동 이전 위치로 되돌리기                    |
| Shift + Cmd + Z    | 위치 Redo       | 되돌린 메모 위치 다시 적용                      |
| Tab                | 생각 사이 이동      | 포스트잇 사이를 키보드로 이동                     |
| Enter              | 편집 시작         | 선택한 포스트잇의 내용 편집으로 들어가기               |
| 방향키                | 위치 이동         | 선택한 포스트잇을 5px씩 이동 ( Shift 와 함께 20px) |
| Esc                | 선택 해제 / 편집 종료 | 편집 중이면 카드로 빠져나오고, 아니면 검색과 선택을 해제     |

마우스 없이도 캔버스를 쓸 수 있습니다. **Tab** 으로 포스트잇을 옮겨 다니고, **Enter** 로 편집에 들어가고, **Esc** 로 나온 뒤 방향키로 위치를 잡습니다.

## 7. 내보내기 (Export)

상단 툴바의 **내보내기 (IconDownload)** 메뉴를 통해 3가지 형식으로 산출물을 추출할 수 있습니다:

1. **Markdown ( .md )**: 메모 제목, 본문, 연결 관계를 정리된 마크다운 문서로 다운로드
2. **Image ( .png )**: 현재 캔버스의 전체 전경을 2000px급 고해상도 투명 PNG 이미지로 다운로드
3. **PDF ( .pdf )**: A4 가로/세로 비율에 맞춰 고품질 PDF 문서로 즉시 생성 및 인쇄

같은 메뉴의 **마크다운 가져오기**로 반대 방향도 가능합니다. 마크다운 파일을 고르거나 텍스트를 붙여넣으면 **#** 제목, **---** 구분선, 빈 줄을 기준으로 나뉘어 각 항목이 하나의 생각으로 캔버스에 붙습니다. 한 번에 최대 200개까지 가져옵니다. 200개를 넘는 초안은 실제 개수를 알려 주고 가져오기 버튼을 비활성화하며, 201번째 이후 내용까지 입력란에 보존하므로 문서를 나눠 안전하게 다시 시도할 수 있습니다. 일부 항목이 실패하면 성공한 항목은 그대로 두고 실패한 항목만 입력란에 남습니다.

모바일에서는 다른 앱의 공유 시트에 umm이 나타납니다. 기사나 메모를 공유하면 캔버스의 빠른 입력창에 내용이 채워진 채로 열립니다.

## 8. 개인 설정 및 API/MCP 키 발급

- **/settings** 메뉴 이동: 우측 상단 프로필 메뉴 또는 네비게이션에서 개인 설정으로 이동합니다.
- **Dream 설정**: Dream 기능 켜기/끄기, 도착 알림, 생성 주기, 스타일 선호도를 지정합니다.
- **연결선 형태 선택**: 베지어 곡선 / 둥근 꺾은선 / 직선 중 선호하는 스타일을 선택합니다.
- **로그인한 기기**: 이 계정에 로그인된 다른 브라우저를 확인하고 개별 종료하거나 한 번에 모두 로그아웃할 수 있습니다. 모르는 기기가 보이면 즉시 종료하고 비밀번호를 바꾸세요.
- **언어와 테마**: 우측 상단 프로필 메뉴에서 한국어/English와 밝게/어둡게/시스템 설정을 고릅니다. 선택은 계정에 저장되므로 다른 브라우저에서도 그대로 따라오고 로그인 직후 현재 탭에도 적용됩니다. 두 선택을 빠르게 연달아 바뀌어도 서로 되돌리지 않습니다.
- **개인 API · MCP 키 발급**:
  1. **새 키** 버튼을 클릭합니다.
  2. 키 이름과 만료 기간을 입력하고 필요한 권한 스코프(Scopes)를 체크합니다.
  3. **키 만들기**를 누르고 생성된 `umm_key_...` Bearer 토큰을 안전한 곳에 복사합니다.
  4. 키 만료 전 **회전** 버튼을 누르면 설정된 중첩 시간(예: 24시간) 동안 구버전/신버전 키가 공존하여 무중단 전환이 가능합니다. 서버의 보안 난수 생성에 문제가 생기면 교체는 실패하고 기존 키 상태가 유지되므로 잠시 뒤 다시 시도하세요.

## 9. 오늘의 리뷰와 다시 보기

로그인 후 기본 화면은 **/today**입니다. 검토 카드에서 **완료**를 누르면 현재 시각이 기록되고, **다시 보기**를 선택하면 지정한 날짜까지 목록에서 미뤄집니다. 검토·고정 상태는 사용자별로 독립되어 공유 생각에서도 다른 참여자의 목록에 영향을 주지 않습니다. 개인 설정의 **리뷰 요약에 활동 포함**을 끄면 최근 댓글 활동만 숨고 고정한 생각, 다시 볼 날짜가 된 생각, 오래 검토하지 않은 생각은 계속 표시됩니다. 연결되지 않은 생각은 캔버스로 열어 다른 생각과 연결할 수 있고, 대기 Dream은 검토함으로 이어집니다. 온보딩 단계는 실제 공간·생각·연결 상태를 기준으로 자동 갱신됩니다.

## 10. 댓글, 멘션과 백링크

포스트잇 메뉴의 **댓글**을 열어 최대 4,000자의 의견을 남깁니다. 같은 공간에 참여한 사용자를 **@username**으로 언급하면 알림이 해당 포스트잇 댓글로 바로 연결됩니다. 작성 중 공간 공유가 회수되면 서버가 현재 멤버십을 transaction에서 다시 확인하므로 이전 권한으로 댓글이나 알림을 만들지 않습니다. 기존 알림도 생각이 삭제되거나 공간 접근권한이 사라지면 목록과 읽지 않은 개수에서 숨겨집니다. 편집 권한이 있는 사용자는 논의를 해결 또는 다시 열 수 있고 작성자·공간 관리자는 삭제할 수 있습니다. 원본 생각이 삭제되거나 공간에서 제거된 뒤에는 이전에 보관한 댓글 주소나 ID로 해결·재개·삭제할 수 없으며, 오프라인에 저장해 둔 해당 변경도 재연결 시 사유를 알리고 제거됩니다. 오른쪽 맥락 패널의 백링크는 들어오는 연결과 나가는 연결을 구분합니다.

## 11. 오프라인 작업과 충돌 해결

---

네트워크가 끊긴 동안의 생성·수정은 브라우저 queue에 저장되고 상단 상태 표시에서 대기 수를 확인할 수 있습니다. 재연결하면 자동 동기화되며 같은 메모의 연속 수정은 마지막 상태로 합쳐집니다. 서버에 더 최신 버전이 있으면 자동 덮어쓰기하지 않고 비교 창을 엽니다. 내 버전, 서버 버전 또는 두 본문을 합친 버전을 선택해 새 버전으로 저장하세요. 삭제된 대상이나 권한 회수 뒤의 댓글 변경처럼 다시 시도해도 적용할 수 없는 변경은 오류 사유를 알린 뒤 해당 항목만 queue에서 제거하고, 뒤의 독립적인 변경은 계속 동기화합니다. 서비스 업그레이드 중 이전 버전 탭을 함께 열어 두었더라도 그 탭이 늦게 기록한 대기 변경은 새 계정 queue와 자동 병합됩니다.

설치형 PWA는 마지막 HTML 앱 셸을 보존합니다. manifest나 아이콘 같은 정적 파일을 주소창에서 직접 열었더라도 앱 셸 캐시를 덮어쓰지 않으므로, 이후 네트워크가 끊겨도 umm 화면으로 다시 진입할 수 있습니다. 새 버전을 배포하면 고정 주소의 manifest·service worker·아이콘은 서버에 재검증되고 content hash가 붙은 bundle만 장기 캐시되어 설치 정보와 바로가기가 이전 릴리스에 고정되지 않습니다.

공용 PC에서는 브라우저 저장소에 오프라인 변경이 남을 수 있으므로 로그아웃 전에 동기화 완료를 확인하고 브라우저 프로필을 종료하세요.

## 12. 접근성 보기와 키보드

---

캔버스 상단에서 선형 목록 보기를 선택하면 공간 위치에 의존하지 않고 생각을 순서대로 읽을 수 있습니다. 포스트잇에 focus한 뒤 화살표 키로 위치를 미세 조정할 수 있으며, 운영체제에서 동작 줄이기를 켜면 불필요한 animation이 비활성화됩니다.

## umm 관리자 운영 가이드 (Admin Guide)

umm은 사내 폐쇄망 및 오프라인 엔터프라이즈 환경에서 외부 의존성 없이 안정적으로 동작하도록 설계되었습니다.

### 1. 런타임 환경변수 4종

서비스 기동 시 필요한 환경변수는 정확히 다음 4개뿐이며, 그 외 모든 정책은 관리자 웹 콘솔에서 런타임으로 관리됩니다:

| 환경변수명                    | 필수 여부 | 설명                       | 예시                                                        |
|--------------------------|-------|--------------------------|-----------------------------------------------------------|
| POSTGRES_DSN             | 필수    | PostgreSQL 데이터베이스 연결 문자열 | postgres://umm:password@postgres:5432/umm?sslmode=disable |
| BOOTSTRAP_ADMIN          | 필수    | 최초 생성할 시스템 관리자 로그인 아이디   | admin                                                     |
| BOOTSTRAP_ADMIN_PASSWORD | 필수    | 부트스트랩 관리자의 초기 비밀번호       | ComplexPassword123!                                       |
| ENCRYPTION_KEY           | 필수    | 비밀값 암호화를 위한 32바이트 AES 키  | 01234567890123456789012345678901                          |

[!NOTE] DB에 이미 bootstrap 관리자가 존재할 경우, 서버를 재시작해도 비밀번호가 임의로 덮어써지지 않습니다.

선택 환경변수 `ENCRYPTION_KEY_PREVIOUS`는 master-key 회전 기간, `UMM_HTTP_ADDR`는 listen 주소 변경, `UMM_TRUSTED_PROXY_CIDRS`는 신뢰할 reverse proxy 주소 지정, 표준 `OTEL_EXPORTER_OTLP_*`는 trace 전송에만 사용합니다. 필수 입력은 네 개로 유지됩니다.

TLS 종료 proxy 뒤에서 실행할 때만 직접 연결되는 proxy의 IP 또는 CIDR을 심표로 구분해 지정하세요(예: `10.42.0.0/16,fd00:42::/64`). 설정하지 않으면 `X-Forwarded-For`, `X-Real-IP`, `X-Forwarded-Proto`를 모두 무시하며, `0.0.0.0/0` 또는 `::/0`처럼 인터넷 전체를 신뢰 대상으로 지정해서는 안 됩니다. Proxy는 외부에서 들어온 forwarding header를 제거하고 자신이 확인한 값을 기록하도록 구성하세요.

브라우저 변경 요청의 `Origin`은 공개 URL 또는 신뢰 proxy로 확인한 현재 요청과 scheme·host·port가 모두 같아야 합니다. HTTPS 서비스와 같은 hostname이더라도 `http://` Origin은 거부됩니다. PostgreSQL request pool 자동 상한은 host CPU 수와 무관하게 인스턴스당 16이며 compose도 이를 명시합니다. `POSTGRES_DSN`의

`pool_max_conns` 는 replica 수와 DB의 전역 연결 한도를 기준으로 조정하세요. 외부 호출 동안 권한을 고정하는 lease는 request pool을 점유하지 않는 별도 연결을 사용하며 AI 호출 최대 2개와 웹훅 전달 최대 3개로 각각 제한됩니다. 전역 연결 예산에는 replica마다 최악의 경우 `+5` 를 더하고, 각 상한을 넘는 lease는 연결 없이 대기합니다. request pool 상한 1~2에서는 전용 LISTEN을 끄고 1초 안전 폴링으로 모든 연결을 request에 남기며, 상한 3부터 listener를 시작하면서 request용 두 자리를 보존합니다. 실행 중 listener 상태가 바뀌면 열린 SSE가 즉시 깨어나 단절 시 1초 폴링, 복구 시 30초 safety net으로 전환합니다. 알림 목록과 짧은 Dream transaction도 작은 pool에서 연결을 중첩 점유하지 않지만 운영에서는 동시 요청과 worker를 위해 `pool_max_conns` 4 이상을 권장합니다.

로그인 세션 목록에 표시하는 User-Agent는 공백과 잘못된 UTF-8을 정리한 뒤 최대 300 byte의 완전한 rune 경계에서 저장합니다. 긴 한국어·다국어 브라우저 식별자가 중간 byte에서 잘려 올바른 자격 증명의 세션 생성이 실패하거나 주소별 로그인 실패 횟수로 잘못 누적되지 않습니다.

---

## 2. Keycloak OIDC SSO 연동

---

`umm` 은 Keycloak OpenID Connect Discovery를 통해 복잡한 설정 없이 엔터프라이즈 SSO를 즉시 연동합니다.

### 1. Keycloak Client 생성:

- Client type: `OpenID Connect`
- Client authentication: `ON` (Confidential)
- Standard Flow: `ON`
- Valid redirect URIs: `https://<umm-domain>/api/v1/auth/oidc/callback`

### 2. 관리자 콘솔 설정 ( `/admin/oidc` ):

- `Keycloak SSO 활성화` 스위치 ON
- Issuer URL: `https://keycloak.company.internal/realms/enterprise`
- Client ID & Client Secret: Keycloak에서 발급받은 자격증명 입력
- 관리자 그룹/역할: `umm-admins`
- 팀장 그룹/역할: `umm-leads`

### 3. 연결 시험:

- `연결 시험` 버튼을 클릭하여 OIDC Discovery 및 토큰 엔드포인트 도달 가능 여부를 실시간 검증합니다.

---

## 3. Dream Layer & 야간 Scheduler 운영

---

Dream Layer는 사용자가 밤사이 휴식하는 동안 캔버스에 쌓인 생각들의 의미적 연관성을 분석하고 새로운 아이디어를 제안하는 핵심 백그라운드 엔진입니다.

생성 결과는 v0.6부터 캔버스에 즉시 삽입되지 않고 개인 Dream 검토함에 후보로 저장됩니다. 사용자가 채택할 때만 Dream 메모와 원본 연결선이 함께 생성되며, 기존 버전에서 이미 캔버스에 생성된 Dream은 업그레이드 시 채택 상태로 보존됩니다.

- 스케줄 설정:

- 자동 생성 스위치 ON
- 생성 시간: 기본 02:00 (사내 심야 시간대)
- 생성 주기: 매일(Daily), 평일(Weekdays), 주말(Weekends), 특정 요일 선택, N일 간격
- 컨텍스트 & 256K 토큰 한도:
  - 최소 메모 개수: 2개 이상 메모가 있어야 분석 시작
  - 분석 범위: 최근 14일
  - 최대 응답 Token: 4K부터 \*\*최대 256K (262,144 tokens)\*\*까지 모델 사양에 맞춰 슬라이더로 조절
- 품질 기준선 (Quality Threshold):
  - 원본 두 개 이상에 대한 근거성, 적정 새로움, 구체성, 출처 범위를 결합한 내부 최소 점수
  - Quiet Mode: 가치가 확실하고 영감을 주는 의미 있는 Dream이 없을 경우 불필요한 노이즈 생성을 건너뛰니다.
- 선택 및 개인정보 보호:
  - 최근 Dream이 적은 적격 공간을 순환하고, 연결되지 않았으나 의미적으로 이어질 수 있는 메모 조합을 우선합니다.
  - 메모 또는 공간에서 AI 제외를 켜면 Scheduler 자격 계산, Dream 생성, AI Assist에서 모두 제외됩니다. 선택적 임베딩 모델을 설정했다라도 제외 콘텐츠는 Gateway로 전송하지 않고 서버 안의 로컬 vector만 사용합니다. AI 제외 공간으로 범위를 제한한 검색어도 Gateway에 보내지 않고 로컬에서 임베딩합니다.
- 운영 지표:
  - 단순 생성 수 외에 검토 완료, 채택률, 편집·연결·확장 기반 유의미 활용률, 채택 Dream당 비용을 함께 확인합니다. 노출 수는 검토함을 불러온 횟수가 아니라 카드가 화면에 50% 이상 실제 표시된 경우만 반영됩니다.

## 4. 내부 AI Gateway 연동

사내망 내부의 LLM Gateway (vLLM, Ollama, TGI, SGLang 등 OpenAI 호환 서버)를 연결합니다.

- Base URL: http://llm-gateway.internal:8000 , .../v1 , 전체 .../chat/completions 주소를 모두 사용할 수 있습니다.
- API Key: 내부 보안 게이트웨이 인증 토큰
- Timeout: 긴 추론 모델을 위해 최대 1800초까지 설정 가능. 이 값은 재시도를 모두 포함한 한 AI 작업의 전체 시간 예산이며, umm HTTP write timeout은 최대값보다 60초 길게 설정됩니다. 앞단 reverse proxy도 설정값보다 최소 60초 길게 응답 timeout을 구성하세요.
- 재시도: 0~5회. 전체 Timeout 안에서만 수행되므로 재시도마다 1800초가 다시 부여되지 않습니다.
- vLLM 추론 모델: 가능하면 서버에 모델별 --reasoning-parser 를 설정합니다. 최종 본문 없이 reasoning / reasoning\_content 만 반환하거나 <think> 도중 출력 한도에 도달하면, 재시도가 1 이상일 때 umm이 비추론 모드로 다시 요청하고 최종 content 만 사용합니다.
- 비용 통계 관리: 입력/출력 1M 토큰당 비용을 입력하면 관리자 대시보드에서 월간 예상 비용과 사용자당 비용을 실시간으로 추산합니다.



- **임베딩 모델:** 비워 두면 외부 호출 없이 내장 로컬 임베딩(문자 n-gram)을 사용합니다. 모델 이름을 넣으면 같은 Gateway의 `/v1/embeddings` 를 사용해 연관 생각·군집·검색의 의미 점수를 계산합니다. 모델이나 Gateway 주소를 바꾸면 endpoint fingerprint가 달라져 기존 생각이 열릴 때마다 점진적으로 다시 임베딩되며, 같은 모델명을 쓰는 서로 다른 제공자의 벡터도 섞여 비교되지 않습니다. 설정 변경 전에 시작한 이전 Gateway 응답은 저장 시점에 현재 설정과 다시 대조되어 폐기되므로 새 벡터를 뒤늦게 덮어쓰지 못합니다. Gateway가 응답하지 않으면 전체 비교 집합을 로컬 임베딩으로 맞추고 5분간 로컬 회로 차단 상태를 유지해 Canvas를 열 때마다 원격 timeout이 반복되지 않습니다. 이 전체 로컬 정규화 pass도 장애가 난 원래 Gateway 설정 세대에 묶여 있으므로, 두 pass 사이에 저장한 새 Gateway의 vector를 덮지 않습니다. 임베딩과 Dream 오류 응답 본문 일부는 다국어 rune 경계를 보존해 관리자 오류와 로그가 유효한 UTF-8을 유지합니다. 설정을 저장하면 회로 차단 상태가 즉시 해제되어 새 설정을 확인합니다.

#### 4-1. 남용 방지 (키 · 권한 → 남용 방지)

로그인 실패와 요청 폭주로부터 서비스를 보호하는 값들입니다. 저장 즉시 적용되며 재시작이 필요 없습니다.

| 항목           | 기본값 | 의미                                                              |
|--------------|-----|-----------------------------------------------------------------|
| 로그인 실패 허용 횟수 | 8   | 같은 주소에서 이만큼 실패하면 잠깁니다. 계정별 임계값은 자동으로 이 값의 3배입니다                 |
| 로그인 잠금 시간    | 15분 | 잠금이 유지되는 시간                                                     |
| 분당 API 요청    | 600 | 호출자별 상한                                                         |
| 분당 AI 요청     | 6   | AI 생성( <code>/ai/assist</code> , Dream 재생성·발전, 관리자 평가 실행) 전용 상한 |
| 하루 AI 생성 한도  | 80  | 사용자별 24시간 상한. <code>0</code> 이면 제한하지 않습니다                       |

롤링 배포 중 구버전 관리자 화면이 새 남용 방지 필드를 모른 채 보안 섹션을 저장해도, 서버는 생략된 로그인·API·AI 한도를 PostgreSQL의 최신 확정값에서 transaction으로 병합합니다. 명시한 값은 `0` 을 포함해 그대로 적용하며 `null` 이나 범위 밖 값은 저장 전에 거부하므로, 업그레이드 도중 운영자가 조정한 한도가 기본값으로 조용히 돌아가지 않습니다.

계정별 임계값을 주소별보다 높게 둔 이유는, 아이디를 아는 사람이 반복 실패를 일으켜 남의 계정을 마음대로 잠글 수 있는 상태를 피하기 위해서입니다. 로그인 성공은 해당 계정의 실패 횟수만 초기화하며, 같은 주소가 다른 계정에 누적한 실패 횟수는 유지되어 정상 계정 로그인으로 주소 제한을 우회할 수 없습니다.

로그인 실패 횟수와 하루 AI 사용량은 데이터베이스에서 관리합니다. 같은 주소·계정의 로컬 로그인은 모든 인스턴스가 공유하는 PostgreSQL 잠금 아래 비밀번호 확인과 실패 기록을 함께 처리하므로 병렬 요청도 설정한 실패 횟수를 초과해 검증되지 않습니다. 대화형 AI, 자동 Dream, 관리자 AI 평가는 실제 Gateway 호출 직전에 PostgreSQL에서 원자적으로 한도 자리를 선점하고 24시간 사용량으로 영속화하므로, 요청 취소·로그 저장 실패·여러 인스턴스의 동시 실행에도 하나의 상한이 적용됩니다. 분당 API 요청 한도는 인스턴스별로 계산되므로, 실효 상한은 `설정값 × 인스턴스 수` 입니다.

## 5. RBAC 사용자 관리 및 불변 감사 로그

### RBAC 3대 역할 체계

- **admin** (관리자): 모든 공간 조회/수정/삭제, 서비스 설정, 사용자 관리, 감사 로그 열람, Dream 수동 큐 생성
- **team\_lead** (팀장): 일반 기능 및 공간 공유 / 외부 내보내기 승인 요청 심사 및 결재 권한
- **user** (일반 사용자): 개인 생각 캔버스 작성, 소유/공유 공간 협업, 개인 키 발급

### 불변 감사 로그 (Immutable Audit Trail)

- 관리자가 수행한 모든 설정 변경, 사용자 역할 수정, 키 발급, 승인 처리 내역이 **audit\_logs** 테이블에 영구 보존됩니다.
- 각 행위의 시각, 행위자, 작업 구분(Action), 대상 리소스(Resource ID)를 투명하게 추적할 수 있습니다.

## 6. 헬스체크 및 성능 지표 모니터링

| 경로              | 메서드 | 용도              | 설명                          |
|-----------------|-----|-----------------|-----------------------------|
| <b>/healthz</b> | GET | Liveness Probe  | 프로세스 생존 상태 및 버전 반환          |
| <b>/readyz</b>  | GET | Readiness Probe | PostgreSQL 연결 및 쿼리 가능 상태 확인 |

운영 현황 화면의 **실시간 협업** 카드는 열려 있는 이벤트 구독 수와 PostgreSQL 수신 상태를 보여 줍니다. 상태가 "폴백 폴링"이면 **LISTEN** 연결이 끊겨 상태 전환 즉시 1초 폴링으로 동작하고 있다는 뜻입니다. 협업은 계속되지만 데이터베이스 부하가 올라가므로 **umm\_realtime\_listener\_up** 지표에 알림을 걸어 두세요. | **/api/v1/metrics** | GET | Prometheus | route별 request count, latency histogram, in-flight, build 정보 ( **metrics:read** ) || **/mcp** | POST | Model Context Protocol | AI 에이전트 도구 연동 엔드포인트 |

표준 OTLP endpoint 환경변수가 설정된 경우에만 OpenTelemetry HTTP trace exporter가 활성화됩니다. 관리자 운영 현황에는 댓글 수, 온보딩 완료율, 최근 웹훅 실패와 AI 평가 통계도 표시됩니다.

## 7. Dream AI 평가 회귀

관리자 → AI 평가에서 최소 두 개의 입력 생각, 기대 단어와 금지 단어, Dream 유형을 저장합니다. 실행은 현재 AI Gateway와 prompt version을 그대로 사용하며 grounding, 기대/금지 단어, 구체성, 모델 응답 상태를 0~1 점수와 세부 항목으로 보존합니다. 모델·prompt·Gateway 설정을 바꾸기 전후에 같은 active case를 실행해 회귀를 확인하세요. Gateway 장애도 **error** run으로 남아 평가 이력이 사라지지 않습니다.

## 8. Master-key 회전

새 키를 **ENCRYPTION\_KEY**, 현재 키를 **ENCRYPTION\_KEY\_PREVIOUS**에 배치한 뒤 재시작합니다. 보안 화면에서 fallback 1개 이상, unreadable 0을 확인하고 **현재 키로 회전**을 실행합니다. 이 작업은 OIDC/AI secret, 웹훅 secret,

암호화 AI prompt를 한 트랜잭션으로 다시 암호화하며 `enc:` wrapper 도입 전 raw v1 AI prompt도 현재 wrapper.v2 형식으로 정규화합니다. 회전 전에 열어 둔 OIDC·AI Gateway 화면에서 마스킹된 값을 동시에 저장해도 서버가 같은 설정 lock 뒤 최신 암호문을 병합합니다. pending 0을 확인하고 새 백업을 만든 후에만 이전 키 환경변수를 제거합니다.

## 9. 서명 웹훅 운영

---

사용자는 개인 설정에서 허용된 `webhooks:write` scope로 subscription을 관리합니다. 대상은 공개 HTTPS 443만 허용합니다. 도메인 변경과 PostgreSQL delivery outbox는 원자적으로 커밋되고, 재시작 시 대기 또는 lease가 만료된 항목을 이어서 처리합니다. 전달 worker는 구독·소유 사용자·이벤트 공간·현재 membership과 정확한 delivery claim을 실제 HTTP 응답까지 잠급니다. 권한 회수·사용자 비활성화·구독 중지가 먼저 확정되면 payload를 보내지 않고, 전송이 먼저 시작되면 변경 transaction은 delivery terminal 상태와 payload 삭제가 확정될 때까지 기다립니다. 수신 시스템은 timestamp와 raw body의 HMAC-SHA256, 허용 시간 창을 검증하고 at-least-once 요청의 delivery UUID를 먹등 처리해야 합니다. 일시 실패는 세 번 재시도하고 연속 10회 실패 subscription은 자동 중지됩니다. 외부 오류는 잘못된 UTF-8을 제거하고 500 byte의 완전한 rune 경계 안에서 기록하므로 다국어 오류도 실패 횟수와 자동 중지를 막지 않습니다. terminal payload는 즉시 제거되고 metadata도 30일 후 정리되므로 운영 지표와 개인 설정의 마지막 오류를 함께 확인하세요.

# umm API & MCP 연동 가이드 (API & MCP Guide)

umm은 시스템 통합 및 자동화를 위한 **REST API**와 AI 에이전트(Claude Desktop, Cursor, Custom Agent 등) 연동을 위한 **Model Context Protocol (MCP)** 엔드포인트를 제공합니다.

## 1. 인증 체계 (Authentication)

모든 API 및 MCP 호출은 개인 설정( /settings )에서 발급받은 **Bearer API Key** 또는 세션 쿠키를 사용합니다:

```
Authorization: Bearer umm_key_a1b2c3d4_XXXXXXXXXXXXXXXXXXXXXXXXXXXX
```

## 2. REST API 주요 엔드포인트 ( /api/v1 )

### 공간 (Spaces)

| 메서드    | 경로                   | 설명                              | 권한 스코프      |
|--------|----------------------|---------------------------------|-------------|
| GET    | /spaces              | 사용자가 접근 가능한 공간 목록 조회            | spaces:read |
| POST   | /spaces              | 새 공간 생성 ( {"name": "새 프로젝트"} )  | notes:write |
| PUT    | /spaces/{id}         | 공간 이름 변경 ( {"name": "수정된 이름"} ) | notes:write |
| DELETE | /spaces/{id}         | 공간 및 내부 메모 영구 삭제                | notes:write |
| GET    | /spaces/{id}/members | 공간 참여 멤버 및 권한 목록 조회             | spaces:read |
| POST   | /spaces/{id}/members | 공간에 사용자 초대                      | notes:write |

## 📝 생각 포스트잇 (Notes & Edges)

| 메서드    | 경로                            | 설명                                                             | 권한 스코프      |
|--------|-------------------------------|----------------------------------------------------------------|-------------|
| GET    | /spaces/{id}/notes            | 공간 내 모든 포스트잇과 연결선 조회                                           | notes:read  |
| POST   | /spaces/{id}/notes            | 새 포스트잇 생성 ( title , content , color , x , y , width , height ) | notes:write |
| PUT    | /notes/{id}                   | 포스트잇 내용/위치/크기 수정                                               | notes:write |
| DELETE | /notes/{id}                   | 포스트잇 삭제                                                        | notes:write |
| GET    | /notes/{id}/history           | 포스트잇 과거 수정 이력 스냅샷 조회                                           | notes:read  |
| POST   | /notes/{id}/restore/{version} | 특정 버전으로 포스트잇 복원                                                | notes:write |
| GET    | /notes/{id}/related           | 의미 유사도 기반 연관 생각 목록 추천                                          | notes:read  |
| GET    | /notes/{id}/backlinks         | 들어오고 나가는 실제 연결선과 상대 생각 조회                                      | notes:read  |
| GET    | /search?q= ...                | 로컬 의미·키워드 하이브리드 검색과 필터 ·cursor                                 | notes:read  |
| GET    | /notes/{id}/comments          | 댓글·멘션 목록                                                       | notes:read  |
| POST   | /notes/{id}/comments          | 댓글 작성과 멘션 알림                                                   | notes:write |
| PUT    | /comments/{id}/resolve        | 댓글 해결·재개                                                       | notes:write |
| POST   | /spaces/{id}/edges            | 두 포스트잇 간 연결선 생성 ( source , target , relation )                 | notes:write |

## 🧠 AI Assist

| 메서드  | 경로         | 설명                                      | 권한 스코프    |
|------|------------|-----------------------------------------|-----------|
| POST | /ai/assist | 선택한 1~20개 생각을 요약·질문·확장·반대 관점·실행 항목으로 발전 | ai:assist |

서버는 선택한 모든 생각이 현재 접근 가능하고 AI 제외 상태가 아닌지 외부 호출 직전에 다시 확인합니다. 해당 note·space·membership 행을 Gateway 응답이 끝날 때까지 잠그므로 공유 회수나 AI 제외가 먼저 확정되면 본문을 보내지 않고 미사용 쿼터를 취소하며, AI lease가 먼저 시작되면 정책 변경은 호출 종료까지 기다립니다. 긴 lease는 일반 요청 pool과 분리된 인스턴스당 최대 2개 PostgreSQL 연결만 사용하므로, 추가 AI 호출이 대기해도 readiness-인증·Canvas용 pool\_max\_conns 를 점유하지 않습니다.

| 메서드  | 경로                   | 설명                                                  | 권한 스코프                                 |
|------|----------------------|-----------------------------------------------------|----------------------------------------|
| GET  | /today               | 검토 대상·고립 생각·댓글·온보딩 집계.<br>Dream 항목은 별도 권한이 있을 때만 포함 | notes:read<br>( dreams:read for Dream) |
| POST | /notes/{id}/review   | 검토 완료, 다시 보기, 고정                                    | notes:write                            |
| GET  | /onboarding          | 실제 사용 기반 온보딩 진행률                                    | 로그인                                    |
| POST | /onboarding/complete | 온보딩 완료 표시                                           | 로그인                                    |

## 🌙 Dream 검토함

| 메서드  | 경로                          | 설명                                            | 권한 스코프                       |
|------|-----------------------------|-----------------------------------------------|------------------------------|
| GET  | /dreams                     | 출처와 상태를 포함한 개인 Dream 검토함 조회                   | dreams:read                  |
| POST | /dreams/{id}/feedback       | 노출·채택·숨김 등의 무중복 피드백 기록                        | dreams:read                  |
| POST | /dreams/{id}/accept         | 후보를 Dream 메모와 출처 연결선으로 확정                     | dreams:read ,<br>notes:write |
| POST | /dreams/{id}/regenerate     | 같은 출처에서 중복되지 않는 다른 관점 생성                      | dreams:read                  |
| POST | /dreams/{id}/develop        | 확장·반대 관점·실행 항목으로 발전                           | dreams:read                  |
| POST | /dreams/{id}/developed-note | 발전 결과를 새 메모와 expanded 연결선으로 원자 저장(동일 재시도 무중복) | dreams:read ,<br>notes:write |

Today의 대기 Dream과 GET /dreams 의 후보·출처는 매 조회마다 Dream이 속한 공간의 현재 owner/member 권한을 확인합니다. 자동 Dream의 원본 선별도 현재 접근 가능한 사용자 작성 생각만 허용하고, 최종 source lease 안에서 자격을 다시 확인합니다. 공간 공유가 회수되면 파생 본문·공간명·원본이 즉시 목록에서 빠지고 보관한 Dream ID로 피드백·숨김·채택·재생성·발전을 요청해도 상태나 개인화를 바꾸지 않습니다. 피드백은 Dream 행과 membership을 같은 transaction에서 잠급니다. 자동 생성·재생성·발전은 AI 제외되지 않은 원본 note, 관련 공간과 현재 membership을 정렬된 순서로 잠그며 Dream 기반 호출은 Dream 행과 공간도 포함한 뒤 그 lease 안에서만 Gateway를 호출합니다. 회수가 먼저 끝나면 외부 호출 전 쿼터 예약을 취소하고 본문을 보내지 않으며, lease가 먼저 시작되면 회수 transaction이 호출 종료 뒤까지 기다립니다. 자동 생성 후보·source·알림과 채택·발전 결과 저장도 각 열린 transaction 안에서 함께 확정합니다. 별도 pool 연결로 권한을 다시 조회하지 않으므로 작은 pool에서도 자신이 보유한 transaction 연결을 기다리지 않습니다.

GET /notifications 의 각 항목에는 resourceType , resourceId , resourceSpaceId , metadata 가 포함됩니다. Dream 알림은 /dreams?focus={resourceId} , 공간 공유 알림은 /space/{resourceId} , 댓글·멘션은 /space/{resourceSpaceId}?note={resourceId} 로 연결할 수 있습니다. note 알림은 현재 생각의 soft-delete 상태와 실제 공간 접근권한을 목록·unread count 양쪽에서 확인하며, 이전 행에 resourceSpaceId 가 없어도 생각이 속한 공간으로 권한을 계산합니다. Dream 알림도 현재 공간 ID를 저장하고 이전 행은 Dream에서 실제 공간을 찾아

공유 회수 뒤 본문을 숨깁니다. unread count와 page 조회는 DB 연결을 겹쳐 잡지 않고 순차 실행합니다.

`pool_max_conns` 1~2에서는 realtime listener도 안전 폴링으로 전환하므로 endpoint가 자신이 필요한 request 연결을 기다리지 않습니다.

개인 설정과 API key 생성·회전·폐기, 세션 관리, 모든 `/admin/*` 작업은 API key가 아니라 로그인한 브라우저 세션에서만 허용됩니다. 제한된 자동화 key가 새 자격 증명을 만들거나 관리자 role을 상속해 권한을 넓힐 수 없습니다. OIDC·AI Gateway 설정에서 마스킹된 secret을 그대로 보내면 서버가 저장 직전의 최신 암호문을 설정별 transaction lock 안에서 병합하며, master-key 회전도 같은 lock을 사용하므로 회전 전에 연 관리 화면의 저장에 새 암호문을 되돌리지 않습니다.

`PUT /preferences` 는 원자적 부분 수정입니다. 바꾸려는 필드만 보내면 되고, 보내지 않은 필드는 요청이 처리되는 시점의 최신 저장값이 유지됩니다. 언어와 테마처럼 서로 다른 설정을 동시에 바뀌도 한 요청이 다른 요청을 되돌리지 않으며, `dream_pause_until: null` 은 일시정지를 명시적으로 해제합니다.

## 로그인한 기기

| 메서드    | 경로                                   | 설명                                                          | 권한      |
|--------|--------------------------------------|-------------------------------------------------------------|---------|
| GET    | <code>/sessions</code>               | 이 계정에 로그인된 브라우저 세션 목록. 요청을 보낸 세션은 <code>current</code> 로 표시 | 브라우저 세션 |
| DELETE | <code>/sessions/{id}</code>          | 특정 세션 종료. 현재 세션을 종료하면 쿠키도 함께 지워짐                            | 브라우저 세션 |
| POST   | <code>/sessions/revoke-others</code> | 이 브라우저를 제외한 모든 로그인 종료                                       | 브라우저 세션 |

세션 토큰은 어떤 응답에도 포함되지 않습니다.

세션의 `userAgent` 는 표시·감사용 정보이며 서버가 유효한 UTF-8의 최대 300 byte로 정규화합니다. 다중 byte 문자는 rune 경계에서만 잘리므로 긴 User-Agent 때문에 올바른 로그인 자체가 실패하지 않습니다.

Canvas 목록·수정 이력·댓글·백링크처럼 본문을 반환하는 조회는 사전 권한 확인 결과를 재사용하지 않고, 콘텐츠를 읽는 PostgreSQL statement 자체에서 현재 공간 owner/member 조건을 확인합니다. 멤버가 제거된 뒤 시작된 조회는 빈 본문을 반환하지 않고 404로 종료됩니다.

댓글 작성은 생각과 공간을 확인한 뒤 호출자의 현재 멤버십 행을 transaction 종료까지 잠급니다. 작성과 권한 회수가 겹치면 먼저 잠금을 얻은 작업이 끝난 뒤 다음 작업이 진행되며, 권한 회수가 먼저 확정된 요청은 댓글·알림·실시간 이벤트·webhook outbox를 만들지 않고 404로 종료됩니다. 생각이 soft-delete되었거나 공간에서 제거된 뒤 보관한 댓글 ID로 해결·재개·삭제를 요청하면 현재 상태를 mutation statement에서 확인하고 `comment-mutation-forbidden` 403 Problem Details로 종료해 행·이벤트·webhook을 바꾸지 않습니다. 이 타입은 재시도해도 적용할 수 없는 오프라인 변경임을 뜻합니다. `review_digest=false` 는 `/today` 의 협업 활동만 제외하고 고정·다시 보기 기한·오래된 생각의 기본 검토 목록은 유지합니다.

`/search` , `/notifications` , `/dreams` , `/admin/audit` 는 응답의 `nextCursor` 를 다음 요청의 `cursor` 에 그대로 전달합니다. cursor 내부 형식에 의존하지 마세요.

하이브리드 검색은 접근 가능한 전체 메모에서 정확 제목·정확 본문·제목 구문·본문 구문 순으로 키워드 후보를 제한 한 뒤 최근 비키워드 후보에 의미 점수를 결합합니다. 따라서 광범위한 단어가 500개 넘는 본문에 포함되거나, 메모가 2,000개를 넘거나, 검색어가 본문 2,000자 이후에 있어도 오래된 정확 결과를 최신 부분 일치 때문에 누락하지 않습니다.

키워드 조건은 `pg_trgm` 인덱스를 사용하며 검색어는 최대 8개 단어까지 반영됩니다(그 이상은 무시되어 결과가 좁아지지 않고 넓어집니다). 한 검색어의 모든 단어는 메모 본문 쪽 또는 공간 이름 쪽 한 곳에서 모두 일치해야 하며, 양 쪽에 나뉘어 걸친 조합은 의미 점수 후보로 넘어갑니다.

## 요청 한도

| 상황                | 응답                | problem type         |
|-------------------|-------------------|----------------------|
| 호출자별 API 요청 한도 초과 | 429 + Retry-After | rate-limited         |
| AI 생성 분당 한도 초과    | 429 + Retry-After | ai-rate-limited      |
| AI 생성 하루 한도 초과    | 429 + Retry-After | ai-daily-limit       |
| AI 쿼터 저장소 일시 오류   | 503 + Retry-After | ai-quota-unavailable |
| 로그인 실패 반복으로 잠금    | 429 + Retry-After | login-locked         |

한도 값은 관리자 설정에서 조정합니다. 구버전 관리 클라이언트가 새 남용 방지 필드를 생략한 채 보안 섹션을 PUT 해도 서버는 PostgreSQL transaction lock 아래 최신 저장값에서 생략 필드만 병합합니다. 명시한 0은 하루 AI 무제한으로 적용되고 null은 잘못된 설정으로 거부됩니다. 로컬 로그인은 정렬된 주소·계정 advisory lock 아래 잠금 확인부터 비밀번호 검증과 실패 기록 또는 session 저장까지 같은 PostgreSQL 연결에서 끝내므로, 여러 replica의 병렬 요청도 login\_max\_failures 보다 많은 추측을 통과시키지 않고 작은 pool에서도 추가 연결을 기다리지 않습니다. 일일 AI 한도는 실제 Gateway 호출 전에 PostgreSQL에서 원자적으로 예약한 뒤 24시간 원장으로 영속화하며, 자동 Dream과 관리자 AI 평가도 같은 원장을 사용합니다. 따라서 replica가 여러 개거나 요청이 취소되거나 별도 ai\_calls 로그 저장이 실패해도 동시에 한도를 넘지 않습니다. 쿼터를 영속화할 수 없으면 비용 보호를 위해 AI 호출을 시작하지 않고 503으로 종료합니다. 429와 503은 재시도 가능한 응답이므로 오프라인 queue도 보존한 뒤 다시 시도합니다.

## 서명 웹훅

/webhooks에서 이벤트 subscription을 만들면 secret이 한 번만 반환됩니다. 대상은 공개 HTTPS 443이어야 하며 HMAC 입력은 아래와 같습니다.

```
signed = X-Umm-Timestamp + "." + raw_request_body
X-Umm-Signature-256 = "sha256=" + hex(HMAC-SHA256(secret, signed))
```

도메인 변경과 활성 구독별 PostgreSQL outbox는 같은 트랜잭션에서 확정되며, 프로세스가 재시작되어도 워커가 대기 항목을 이어서 처리합니다. 워커는 정확한 delivery claim과 구독·소유 사용자·이벤트 공간·현재 membership을 실제 HTTP 응답까지 하나의 authorization lease로 잠급니다. 권한 회수·사용자 비활성화·구독 중지가 먼저 확정되면 캡처한 payload를 보내지 않고, 전달이 먼저 시작되면 정책 변경은 terminal 상태와 payload 삭제가 확정될 때까지 기다립니다. 이 lease는 일반 request pool 밖의 인스턴스당 최대 3개 연결을 사용합니다. 전달 시도는 at-least-once 방



식이므로 수신 측은 `X-Umm-Delivery` 를 먹등 키로 사용해 중복을 무시하고 timestamp 허용 시간도 함께 확인해야 합니다. terminal payload는 즉시 비워지고 delivery metadata는 30일 보존됩니다. 이벤트에는 `space.updated` , `note.*` , `edge.created` , `comment.*` , `member.*` , `dream.accepted` 가 있습니다.

## 안전한 재시도와 오류

Canvas의 메모·연결·댓글 생성/수정/삭제 요청에 8~128자의 `Idempotency-Key` 를 보내면 같은 사용자와 키의 성공 응답을 24시간 재생합니다. 서버는 method·경로·query·본문 fingerprint가 같은 요청만 재생하며, 다른 요청에 키를 재사용하면 409입니다. 처리 중 2분 lease는 handler가 살아 있는 동안 갱신되고, 아직 처리 중이면 `Retry-After` 가 포함된 425를 반환합니다. 도메인 변경·SSE·webhook outbox·먹등 성공 응답은 같은 PostgreSQL 트랜잭션으로 확정되므로 성공 응답 기록 실패가 mutation 중복을 만들지 않습니다. handler 실행 전 프로세스가 중단되면 lease 만료 후 같은 요청이 예약을 자동 재획득합니다. 오프라인 클라이언트는 한 논리 작업에 같은 키를 유지하고 `Retry-After` 이후 다시 시도해야 합니다. 장시간 AI 요청과 API key·웹훅 서명 key처럼 비밀을 한 번만 공개하는 요청은 `Idempotency-Key` 를 거부합니다.

오류 본문은 `application/problem+json` 이며 `type` , `title` , `status` , `detail` 을 제공합니다. 기존 클라이언트를 위해 `error` 도 같은 설명을 유지합니다. 접근 가능한 메모의 version 충돌만 409와 `clientVersion` , 최신 서버 `latest` 메모를 반환합니다. 메모가 삭제되었거나 공간 접근 권한을 잃은 경우에는 404로 종료합니다.

브라우저 오프라인 queue는 409 충돌과 408·425·429·5xx처럼 다시 시도할 수 있는 응답만 보존하고 일시 오류는 `Retry-After` 또는 기본 5초 뒤 자동 재시도합니다. 400·404 등 영구적인 client 오류는 사용자에게 사유를 알린 뒤 queue에서 제거해 무한 재시도를 막습니다. 메모를 볼 수는 있지만 공간 권한이 `edit` 에서 `view` 로 낮아진 `note-read-only` , 더는 댓글을 바꿀 수 없는 `comment-mutation-forbidden` 403은 일반 인증/권한 403과 구분해 해당 변경만 제거하고 이후 항목을 계속 동기화합니다. flush 도중 다른 탭이나 새 편집이 추가한 항목은 최신 queue와 ID 단위로 병합하고 탭 간 Web Lock으로 저장을 직렬화해 진행 중이던 snapshot이 덮어쓰지 않습니다.

## ⚡ 실시간 이벤트 스트림 (SSE)

- 경로: `GET /api/v1/spaces/{spaceID}/events`
- 프로토콜: Server-Sent Events (SSE)
- 이벤트 타입: `space-change`
- 용도: 타 사용자가 캔버스에서 포스트잇을 추가/수정/이동할 때 실시간 브로드캐스트 수신
- 재개: 각 이벤트의 `id` 가 `space_events.sequence` 입니다. 재연결 시 `Last-Event-ID` 헤더 또는 `?after=` 쿼리로 마지막 sequence를 전달하면 그 이후부터 이어받습니다.
- 전달 방식: 서버는 PostgreSQL `LISTEN/NOTIFY` 로 깨어나 즉시 전송합니다. 구독자 수와 무관하게 유휴 상태에서는 데이터베이스를 조회하지 않습니다. 수신 연결 상태가 바뀌면 열린 SSE를 즉시 깨우고 cursor 이후를 다시 조회한 뒤, 단절 중에는 1초 폴링으로 전환하고 복구 시 30초 safety net으로 돌아가므로 클라이언트가 알아차릴 필요는 없습니다.

## 3. Model Context Protocol (MCP) 엔드포인트

- 엔드포인트: `POST /mcp`
- 인증: `Authorization: Bearer <API_KEY>`

- 프로토콜: JSON-RPC 2.0 (Stateless HTTP POST)

## 제공 도구 목록 (Tools)

1. `list_spaces` : 접근 가능한 공간 목록 조회
2. `list_notes` : 지정된 공간의 생각 포스트잇 및 연결선 조회
3. `create_note` : 캔버스에 새로운 생각 포스트잇 생성
4. `connect_notes` : 두 생각 간의 연결선 생성
5. `search_notes` : 지정 공간의 생각 검색
6. `get_related_notes` : 오프라인 유사도 기반 연관 생각 조회
7. `list_clusters` : 생각 군집 조회
8. `list_dreams` : 출처와 검토 상태를 포함한 최근 Dream 조회

## MCP 호출 예시 (JSON-RPC 2.0)

요청: 생각 포스트잇 생성

```
{
  "jsonrpc": "2.0",
  "id": "req-101",
  "method": "tools/call",
  "params": {
    "name": "create_note",
    "arguments": {
      "space_id": "3fa85f64-5717-4562-b3fc-2c963f66afa6",
      "content": "MCP 엔드포인트를 통해 Cursor나 Claude에서 직접 생각을 붙이고 연결할 수 있습니다.",
      "color": "lavender",
      "x": 400,
      "y": 250
    }
  }
}
```

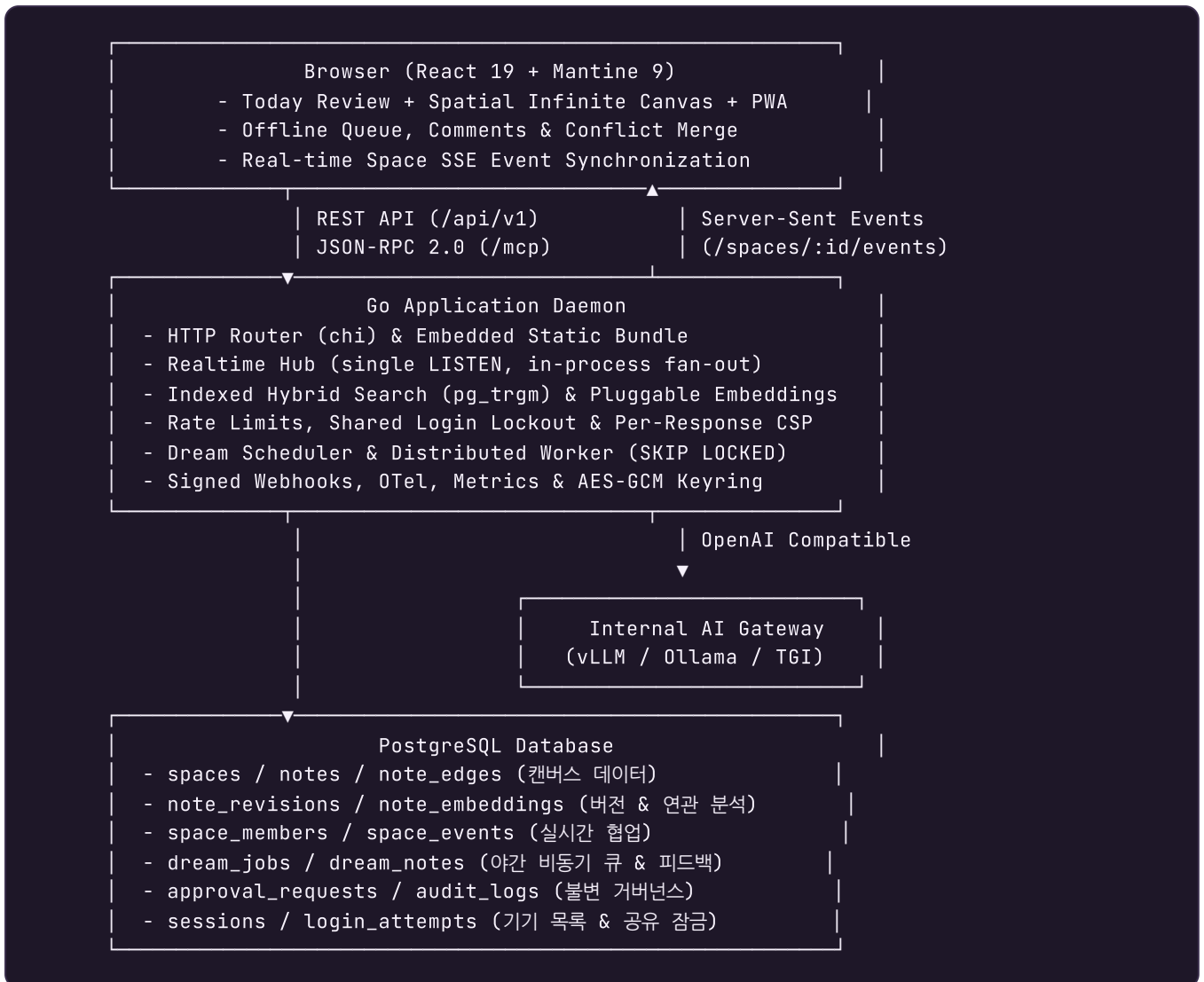
응답

```
{
  "jsonrpc": "2.0",
  "id": "req-101",
  "result": {
    "content": [
      {
        "type": "text",
        "text": "생각 포스트잇이 성공적으로 생성되었습니다. (ID: 9b1deb4d-3b7d-4bad-9bdd-2b0d7b3dcb6d)"
      }
    ]
  }
}
```

## umm 실행 아키텍처 및 불변 조건 (Architecture)

umm은 단일 Go 바이너리와 단일 PostgreSQL 인스턴스만으로 오프라인 폐쇄망에서 무중단 운영이 가능하도록 설계된 **Spatial Thought Memory** 엔진입니다.

### 1. 시스템 아키텍처 다이어그램



### 2. 데이터 경계 및 도메인 분리

- **Canvas Domain:** spaces, notes, note\_edges
- **Intelligence Domain:** note\_revisions, note\_embeddings
- **Collaboration Domain:** space\_members, space\_events, notifications, note\_comments, comment\_mentions

- **Identity & Access:** `users`, `sessions`, `oauth_states`, `teams`, `login_attempts`, `ai_quota_reservations`
- **Personalization & Review:** `user_preferences`, `note_reviews`, `api_keys`
- **Governance & Security:** `approval_requests`, `audit_logs`, `app_settings`
- **Dream & LLM Domain:** `dream_jobs`, `dream_notes`, `dream_sources`, `dream_feedback`, `ai_calls`, `ai_eval_cases`, `ai_eval_runs`
- **Automation & Reliability:** `webhook_subscriptions`, `webhook_deliveries`, `idempotency_records`, `product_events`

### 3. 핵심 아키텍처 원칙

#### 1. 외부 의존성 없는 의미 연관성 분석 (Offline Semantic Engine)

- 연관 생각(Related Thoughts)과 클러스터링은 기본적으로 **192차원 문자 n-gram feature hashing**과 **cosine similarity**로 계산됩니다. 외부 다운로드나 API 호출이 없어 폐쇄망에서 100% 동작합니다.
- v0.8.0부터 관리자가 AI Gateway에 임베딩 모델을 지정하면 OpenAI 호환 `/v1/embeddings`를 대신 사용합니다. 모든 벡터에는 모델명과 정규화된 Gateway endpoint의 SHA-256 fingerprint로 만든 알고리즘 식별자가 함께 저장되고 **같은 알고리즘끼리만 비교**합니다. 모델 또는 Gateway를 바꾸면 같은 모델명을 유지해도 서로 다른 벡터 공간이 뒤섞이지 않고 점진적으로 다시 임베딩됩니다. API key와 timeout은 벡터 공간을 바꾸지 않으므로 fingerprint 대상에서 제외합니다. 원격 응답과 장애 뒤 비교 집합을 로컬로 통일하는 후속 pass를 저장하는 transaction은 모두 작업 시작 시점의 `ai_gateway` 설정 세대로 현재 설정 행을 shared lock 확인하므로, 두 pass 사이 또는 호출 중 설정이 바뀌어도 이전 결과가 새 Gateway의 벡터를 덮어쓸 수 없습니다. 콘텐츠 version이 낮은 벡터도 알고리즘이 다르다는 이유만으로 최신 행을 교체하지 못합니다.
- 게이트웨이 호출이 실패하면 로컬 벡터로 내려가되 저장되는 알고리즘 이름은 로컬로 기록됩니다. 실패한 호출이 성공한 것처럼 남는 경로는 없습니다. 공간으로 범위를 제한한 검색은 접근권한과 `ai_excluded`를 먼저 함께 확인하며, 제외 공간의 검색어도 원격 Gateway로 보내지 않습니다.

#### 1-1. 푸시 기반 실시간 협업 (Realtime Hub)

- `space_events`의 AFTER INSERT 트리거가 `pg_notify`를 호출합니다. PostgreSQL은 알림을 커밋 시점에 전달하므로, 롤백된 변경이 다른 사람에게 보이는 상태는 만들어질 수 없습니다.
- 인스턴스마다 전용 연결 하나가 `LISTEN umm_space_events`를 유지하고, 도착한 알림을 프로세스 안의 구독자에게 팬아웃합니다. 구독자 수와 무관하게 데이터베이스 부하는 일정합니다. 단 `pool_max_conns`가 1 또는 2이면 전용 리스너를 시작하지 않고 기존 1초 안전 풀링을 사용해 request pool의 모든 연결을 readiness·인증·transaction 요청에 남깁니다. 상한 3부터 listener를 시작하면서 request용 두 연결을 보존합니다. 목록과 unread count를 함께 반환하는 알림 endpoint는 count와 rows를 순차 실행해 request 연결 하나만 사용하고, 짧은 Dream 채택 transaction도 같은 연결에서 권한을 확인합니다. 외부 호출 동안 유지하는 access lease는 request pool과 분리해 AI 최대 2개, 웹훅 최대 3개로 각각 제한하므로 인스턴스의 최악 연결 상한은 `pool_max_conns + 5`입니다.
- 알림은 페이로드를 신뢰하지 않습니다. 깨어난 리더는 자신이 마지막으로 보낸 sequence 이후를 다시 조회하므로, 알림이 합쳐지거나 유실되어도 이벤트를 건너뛰지 않습니다.

- 리스너가 끊기면 지수 백오프로 재연결합니다. 연결 상태 전환 자체가 모든 SSE 구독자를 coalesced 신호로 즉시 깨우므로, 리더는 기존 30초 safety-net deadline을 기다리지 않고 cursor를 따라잡은 뒤 타이머를 1초 폴링으로 재설정합니다. 재연결 신호에서는 다시 30초 안전망으로 돌아가며 협업이 멈추는 구간이 없습니다.

## 1-2. 인덱스를 타는 하이브리드 검색

- 키워드 조건은 `단어마다 하나의 ILIKE` 를 AND로 묶은 형태로 생성됩니다. 각 조건이 `pg_trgm` GIN 인덱스를 타고 PostgreSQL이 비트맵을 교집합합니다.
- 인덱스는 `(title || ' ' || content)` 표현식 위에 만들어집니다. 코드의 표현식과 한 글자라도 달라지면 조용히 순차 스캔으로 되돌아가므로, 두 값이 일치하는지 검사하는 테스트를 함께 둡니다.
- 의미 점수 후보는 최근 문서로 상한을 둡니다. 큰 워크스페이스에서 한 번의 검색이 전체 스캔이 되지 않게 하기 위해서입니다.

## 2. 낙관적 동시성 제어 (Optimistic Concurrency Control)

- 각 생각 노드는 단조 증가하는 `version` 번호를 가집니다.
- 다중 사용자가 동시에 작업하더라도 버전 충돌을 감지하고 409 Problem Details에 최신 서버 메모를 포함합니다. 브라우저는 내 변경과 서버 변경을 나란히 보여 주고 선택·병합한 뒤 새 버전으로 저장합니다.
- 오프라인 변경은 PWA local queue에 먹통 키와 함께 보관됩니다. 재연결 시 안전한 순서로 replay하고 같은 메모의 연속 PUT은 마지막 상태로 합칩니다. 인증 복구 가능성이 있는 일반 401/403은 queue를 멈추지만, 공간에서 제거되었거나 생각이 삭제되어 댓글 해결·삭제를 더는 적용할 수 없는 경우 서버가 `comment-mutation-forbidden` 403을 반환하므로 그 항목만 사유를 알리고 제거한 뒤 이후의 독립 변경을 계속 처리합니다. 서비스 워커의 `/` 앱 셀 캐시는 성공한 `text/html` 탐색 응답만 갱신하므로 manifest·asset JSON·SVG를 주소창에서 직접 열어도 오프라인 셀이 비-HTML 응답으로 바뀌지 않습니다. 8자 content hash가 붙은 `assets/` bundle만 1년 immutable이고, manifest·service worker·아이콘·asset manifest 같은 고정 URL은 `no-cache` 로 매 배포 재검증합니다.

## 3. 분산 큐 & DB 트랜잭션 (SKIP LOCKED)

- 외부 메시지 브로커(RabbitMQ, Redis 등) 없이 PostgreSQL의 `FOR UPDATE SKIP LOCKED` 를 활용하여 Dream 백그라운드 작업을 분산 워커 간 중복 없이 안전하게 임대(Lease) 처리합니다.
- 생성된 Dream은 `dream_notes.note_id IS NULL` 인 검토 후보로 먼저 저장됩니다. Today·검토함·상세와 source query는 Dream 소유권뿐 아니라 현재 공간 owner/member 권한을 함께 확인하므로 공유가 회수되면 파생 본문·공간명·원본도 응답에서 빠집니다. AI Assist와 자동 Dream 생성은 선택·선별된 원본 note 행, 원본 공간 행과 membership을 잠그며 재생성·발전은 Dream 행과 Dream 공간까지 같은 lease에 포함합니다. 공간 ID를 정렬된 순서로 잠근 채 외부 Gateway 호출 종료까지 유지하므로, 공유 회수가 먼저 확정되면 쿼터 예약을 호출 전에 취소하고 AI lease가 먼저 시작되면 회수가 호출 종료까지 기다립니다. 긴 lease는 request pool을 빌리지 않는 인스턴스당 2-slot PostgreSQL 용량으로 제한되어 세 번째 호출은 연결을 점유하지 않고 대기합니다. 자동 생성에서 품질을 통과한 Dream·source·알림도 이 transaction에서 함께 확정되어 point-in-time 조회 뒤 권한 변경으로 본문이나 부분 후보가 남지 않습니다. 채택 요청은 같은 방식으로 현재 공간·편집 membership을 잠근 뒤 메모와 `dreamed` 연결선을 한 번만 생성합니다. 채택 후 발전 결과도 같은 권한·Dream 행 잠금 아래 새 메모와 `expanded` 연결선을 원자적으로 만들며, 동일 본문 재시도는 기존 결과를 반환합니다.
- Dream 노출·숨김·선호 피드백은 목록 응답 시점이 아니라 브라우저 `IntersectionObserver` 에서 카드가 50% 이상 보인 시점에 기록됩니다. 서버는 Dream 행과 현재 공간 membership을 같은 transaction에서 잠근 뒤 상태

와 개인화 점수를 함께 확정하므로 권한 회수 뒤 보관한 ID로 피드백을 만들 수 없습니다. 알림의

`resourceType/resourceId` 는 Dream 카드 또는 공유 공간 딥링크로 해석됩니다.

- 공간·메모의 `ai_excluded` 정책은 Scheduler 자격 계산과 AI Assist·Dream Gateway 직전의 최종 source lease 에서 모두 다시 적용되어, 설정 변경 이후의 신규 AI 처리에서 제외됩니다.

#### 4. Daily review와 하이브리드 탐색

- `/today` 는 14일 이상 검토하지 않은 생각, 사용자가 지정한 다시 보기, 연결선이 없는 생각, 대기 Dream, 최근 댓글을 현재 권한과 삭제 상태 범위 안에서 집계합니다. 알림 목록과 unread count도 note 알림의 현재 생각 행과 Dream 알림의 현재 Dream 행을 join해 실제 공간 접근권한을 같은 기준으로 적용하며, legacy 알림의 비어 있는 `resource_space_id` 를 신뢰 경계로 사용하지 않습니다. `note_reviews` 가 공유 메모의 검토·고정 상태를 사용 자별로 분리하고, `review_digest` 는 협업 활동 query만 제어해 기본 검토 신호를 제거하지 않습니다.
- 검색은 완전 로컬 192차원 feature-hash cosine 점수와 제목·본문·공간 키워드 점수를 결합합니다. 응답용 본문 일부가 잘려도 전체 본문의 키워드 일치 플래그를 점수에 보존하며, 공간·종류·수정 시각 필터와 opaque cursor를 지원합니다.
- 백링크는 실제 `note_edges` 의 incoming/outgoing 방향을 반환하며 연관 생각은 의미 유사성을 보완합니다.

#### 5. 자동화·관측성·공급망

- 도메인 변경, PostgreSQL SSE log, 활성 구독별 `webhook_deliveries` outbox는 같은 트랜잭션에서 커밋됩니다. 세 워커가 가용 dispatch slot을 확보한 뒤 `FOR UPDATE SKIP LOCKED` 로 대기 또는 lease가 만료된 처리 항목을 선점하므로 프로세스 재시작과 순간 부하 뒤에도 전달을 이어갑니다. 각 워커는 `claimed_at` 세대가 정확히 일치하는 delivery와 subscription·owner·space·membership을 잠그고 실제 HTTP 응답, terminal delivery 전환, payload 삭제, subscription counter 갱신까지 같은 transaction에서 확정합니다. 권한 회수·사용자 비활성화·구독 중지가 먼저 끝나면 외부 전송을 시작하지 않고, 전달 lease가 먼저 시작되면 정책 변경이 그 종료까지 기다리므로 point-in-time 확인 뒤 캡처한 payload가 새 정책을 넘어 나가지 않습니다. HMAC 서명, SSRF 재검증, 제한 재시도와 자동 중지를 적용하며, at-least-once 전달 시도의 중복은 delivery UUID로 수신 측이 제거합니다. terminal metadata는 30일 보존합니다. 외부 오류는 잘못된 UTF-8을 제거하고 byte 상한 안의 완전한 rune 경계에서 잘라 PostgreSQL 상태 전환과 실패 횟수 갱신을 안정적으로 끝냅니다.
- HTTP 계층은 low-cardinality route pattern으로 Prometheus count·latency를 기록합니다. 표준 OTLP 환경변수가 있을 때만 OpenTelemetry exporter를 초기화합니다.
- 태그 파이프라인은 offline image archive와 SPDX SBOM을 만들고 checksum 및 GitHub artifact attestation을 발급합니다.

#### 6. 남용 방지와 수평 확장의 경계

- 로그인 실패 횟수와 AI 하루 사용량은 PostgreSQL에서 셉니다. 비밀번호 확인부터 실패 기록 또는 session commit까지 주소·계정별 advisory transaction lock 안에서 처리하고 모든 DB 작업은 같은 연결을 사용하므로, 인스턴스가 여러 대이거나 pool 상한이 1이어도 병렬 추측이 설정한 실패 상한을 넘어가지 않습니다.
- 일반 API 요청 한도는 인스턴스별 인메모리 토큰 버킷입니다. 요청마다 데이터베이스를 왕복하면 막으려는 부하보다 비용이 커지기 때문이며, 그 결과 실패 상한은 `설정값 × 인스턴스 수` 가 됩니다. 전역으로 지켜져야 하는 한도는 앞의 두 가지이고, 그것은 데이터베이스에서 셉니다.
- 보안 섹션의 whole-object PUT은 설정별 PostgreSQL advisory transaction lock을 얻은 뒤 최신 행을 읽고, 구버전 payload가 생략한 다섯 남용 방지 필드만 병합합니다. OIDC `client_secret` 과 AI Gateway `api_key` 의 마

스킹 저장도 같은 방식으로 비밀 필드를 생략해 최신 암호문을 transaction 안에서 병합하며, master-key 회전은 같은 두 lock을 정해진 순서로 잡고 재암호화합니다. 동시 관리자 저장과 롤링 업그레이드·키 회전이 겹쳐도 먼저 확인한 한도나 새 암호문을 stale snapshot으로 지우지 않으며 명시한 0은 omission과 구분합니다.

- 계정별 로그인 잠금 임계값은 주소별의 3배입니다. 아이디를 아는 사람이 남의 계정을 임의로 잠글 수 있는 상태를 피하기 위한 의도적인 비대칭입니다.
- 만료된 세션·OAuth state·재시도 기록·로그인 실패 기록은 15분마다 정리됩니다. 모든 인스턴스가 동시에 실행해도 안전합니다.
- `scripts/multi-instance-smoke.sh`가 이 세 가지(교차 인스턴스 이벤트 전달, 교차 인스턴스 맥등 재시도, 공유 로그인 잠금)를 CI에서 실제로 검증합니다.